Zero Knowledge (About) Encryption

A Comparative Security Analysis of Three Cloud-based Password Managers

Matteo Scarlata, **Giovanni Torrisi**, Matilda Backendal, Kenny Paterson

ETH Zurich & USI Lugano

Zero Knowledge (About) Encryption

A Comparative Security Analysis
of ~~Three~~ Cloud-based Password Managers
Four

Matteo Scarlata, **Giovanni Torrisi**, Matilda Backendal, Kenny Paterson

ETH Zurich & USI Lugano

Università della Svizzera italiana

ETH zürich

Username: _____

Password: _____

Username: m_____

Password: _____

Username: ma_____

Password: _____

Username: mat_____

Password: _________

Username: matt____

Password: _________

Username: matte___

Password: _________

Username: matteo__

Password: _____

Username: matteo__

Password: *_______

Username: matteo__

Password: **_____

Username: matteo__

Password: ***_____

Username: matteo__

Password: ****____

Username: matteo__

Password: *****___

Username: matteo__

Password: ******__

Username: matteo__

Password: *******_

Username: matteo__

Password: ********

Password Managers

bitwarden

LastPass

DASHLANE

1Password

bitwarden

LastPass

DASHLANE

1Password

✓ Remembers your passwords

bitwarden

LastPass

DASHLANE

1Password

- ✓ Remembers your passwords
- ✓ Won’t accidentally get destroyed in the laundry

bitwarden

LastPass

DASHLANE

1Password

- Remembers your passwords
- Won’t accidentally get destroyed in the laundry
- More Secure™

bitwarden

LastPass

DASHLANE

1Password

60 million users

300k businesses

28% market share

Password Managers

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org

Username: matte0
Password: Pw123$
Url     : c.net
```

Password Managers

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org

Username: matte0
Password: Pw123$
Url     : c.net
```

item

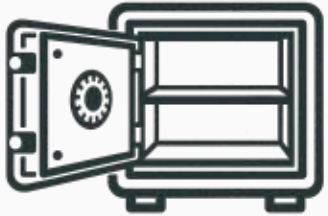
Password Managers

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org

Username: matte0
Password: Pw123$
Url     : c.net
```

item



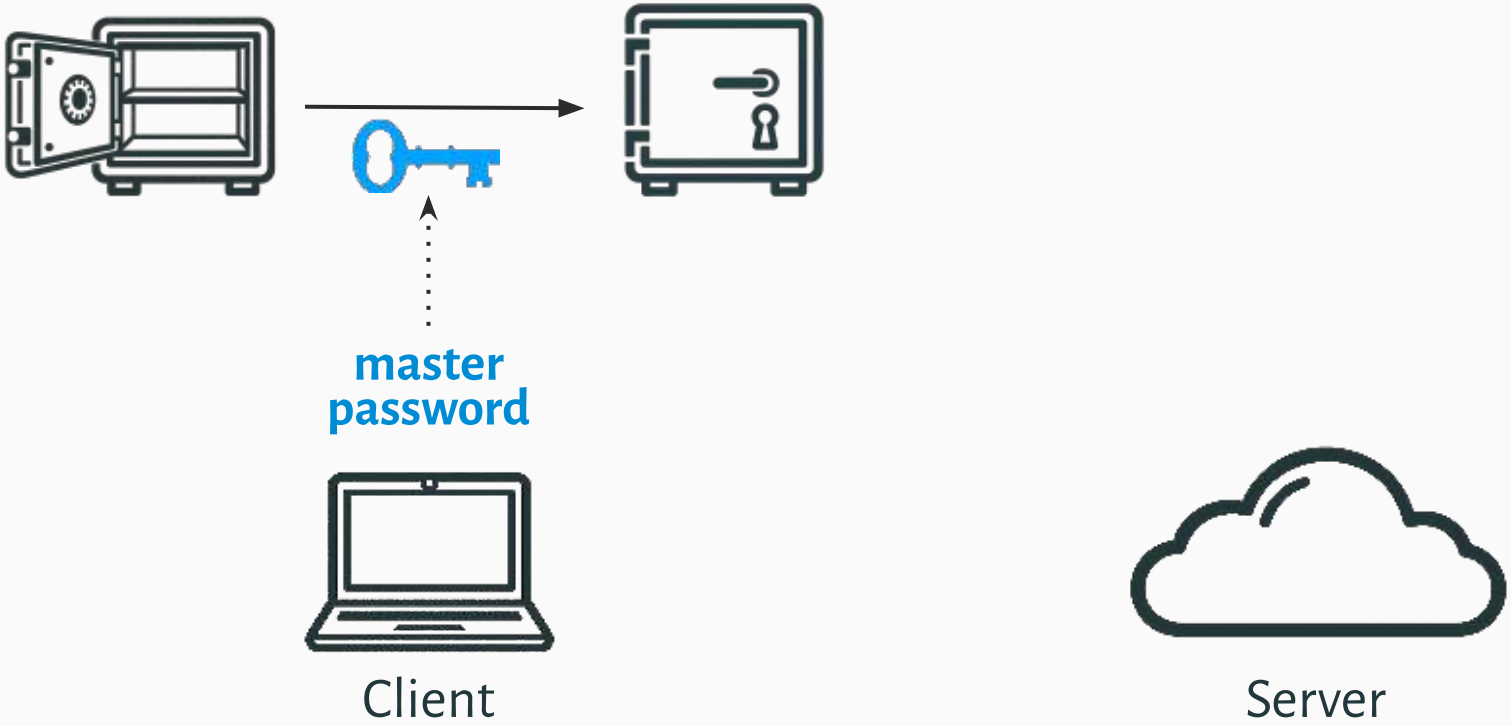
vault

Cloud-based Password Managers

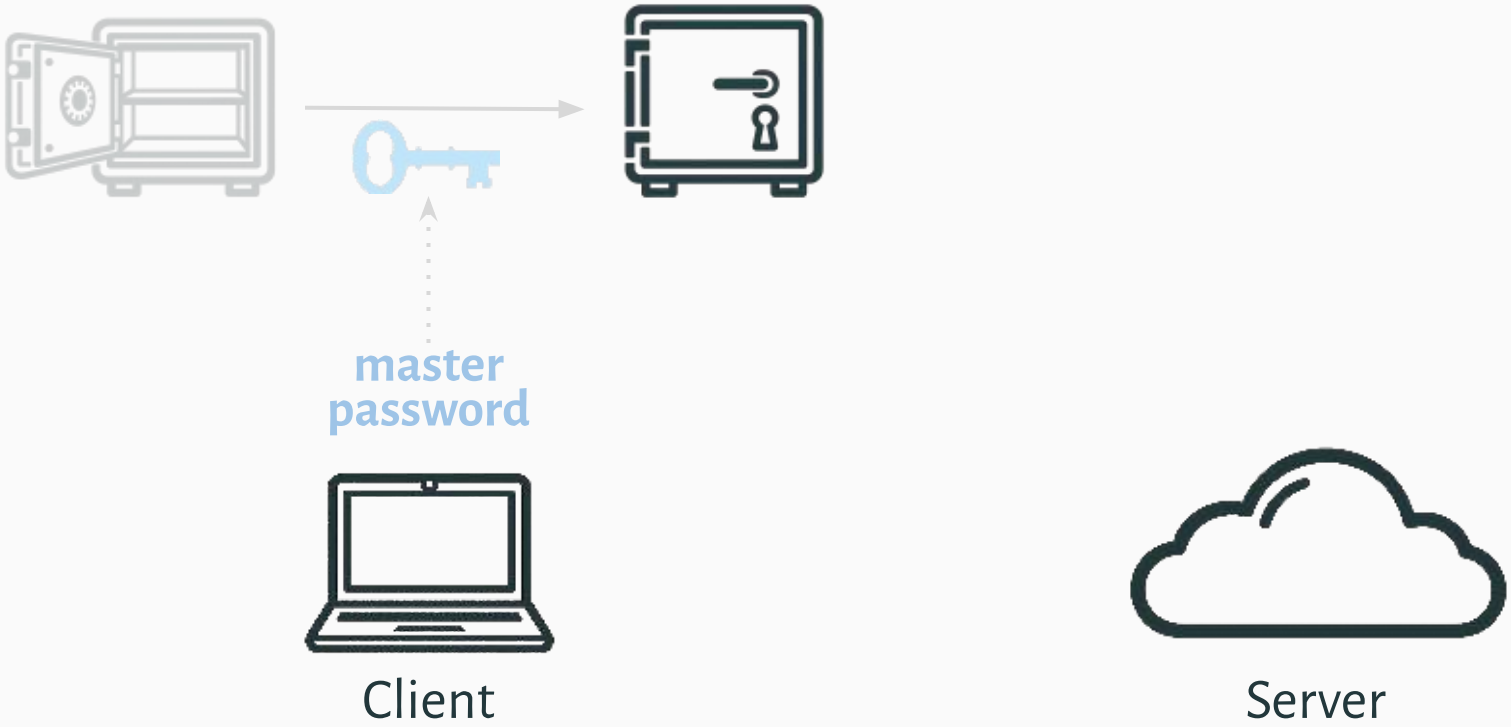
Client

Server

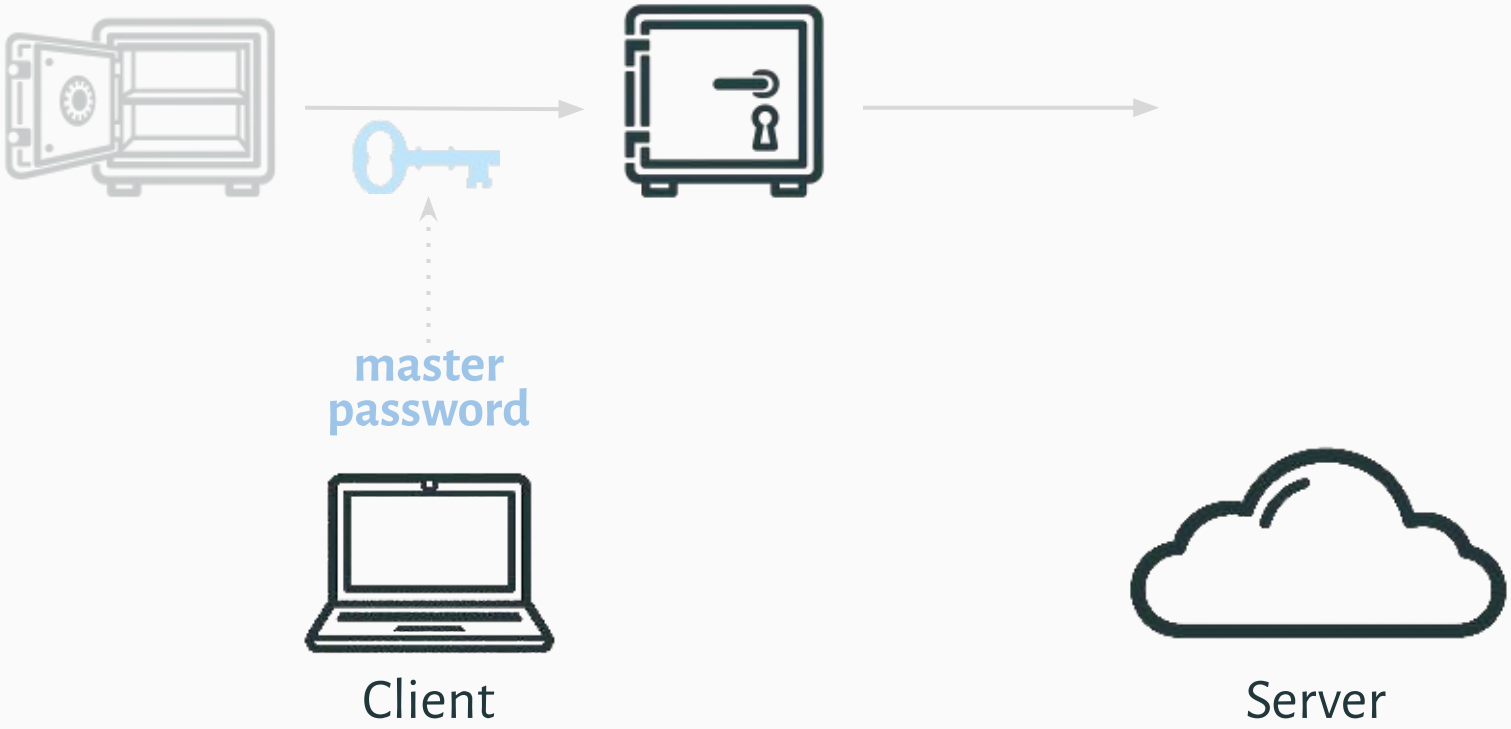
Cloud-based Password Managers



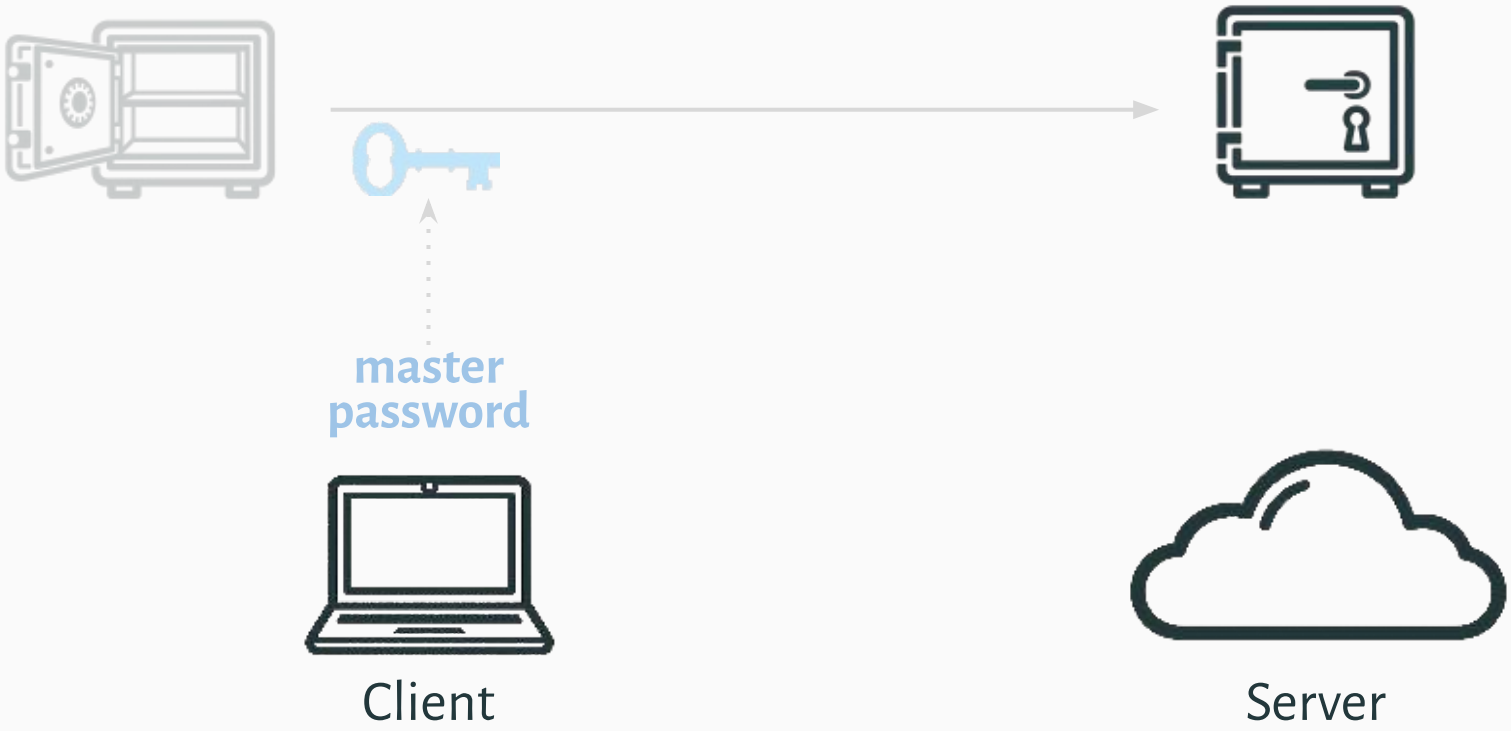
Cloud-based Password Managers



Cloud-based Password Managers



Cloud-based Password Managers



```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

Security

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

Security - What We Expect

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

No master password ⇒ No access to vault

Security - What We Expect

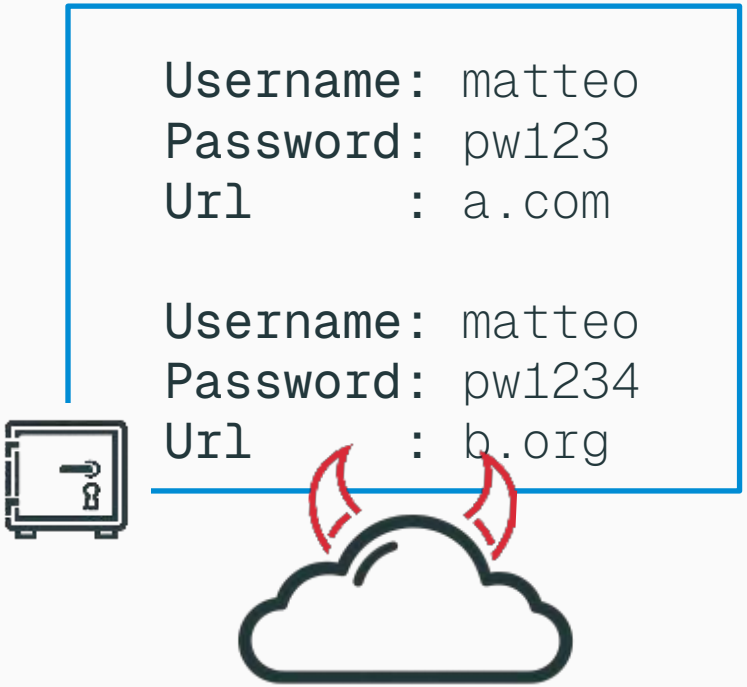
```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

No master password ⇒ No access to vault

No matter what the server does

Security - What We Expect



No master password ⇒ No access to vault

No matter what the server does

Security - What They Promise

ZERO

ZERO KNOWLEDGE

ZERO KNOWLEDGE ENCRYPTION

Security - What They Promise

*... **not even the team** at Bitwarden can read your data (**even if we wanted to**).*

bitwarden

Security - What They Promise

*... **not even the team** at Bitwarden can read your data (**even if we wanted to**).*

bitwarden

***no one has access** to [...] the data stored in your LastPass vault, except you (**not even LastPass**).*

LastPass

Security - What They Promise

*... **not even the team** at Bitwarden can read your data (**even if we wanted to**).*

bitwarden

*... malicious actors **can't steal the information**, even if Dashlane's **servers are compromised**.*

DASHLANE

***no one has access** to [...] the data stored in your LastPass vault, except you (**not even LastPass**).*

LastPass

Security - What They Promise

*... **not even the team** at Bitwarden can read your data (**even if we wanted to**).*

bitwarden

*... malicious actors **can't steal the information**, even if Dashlane's **servers are compromised**.*

DASHLANE

***no one has access** to [...] the data stored in your LastPass vault, except you (**not even LastPass**).*

LastPass

*no one but you — **not even the company** that's storing the data — **can access** and decrypt **your data**.*

1Password

Security - What They Promise

ZERO KNOWLEDGE ENCRYPTION

Security - What They Promise

ZERO KNOWLEDGE ENCRYPTION

E2EE

WHAT WE EXPECT

is

E2EE

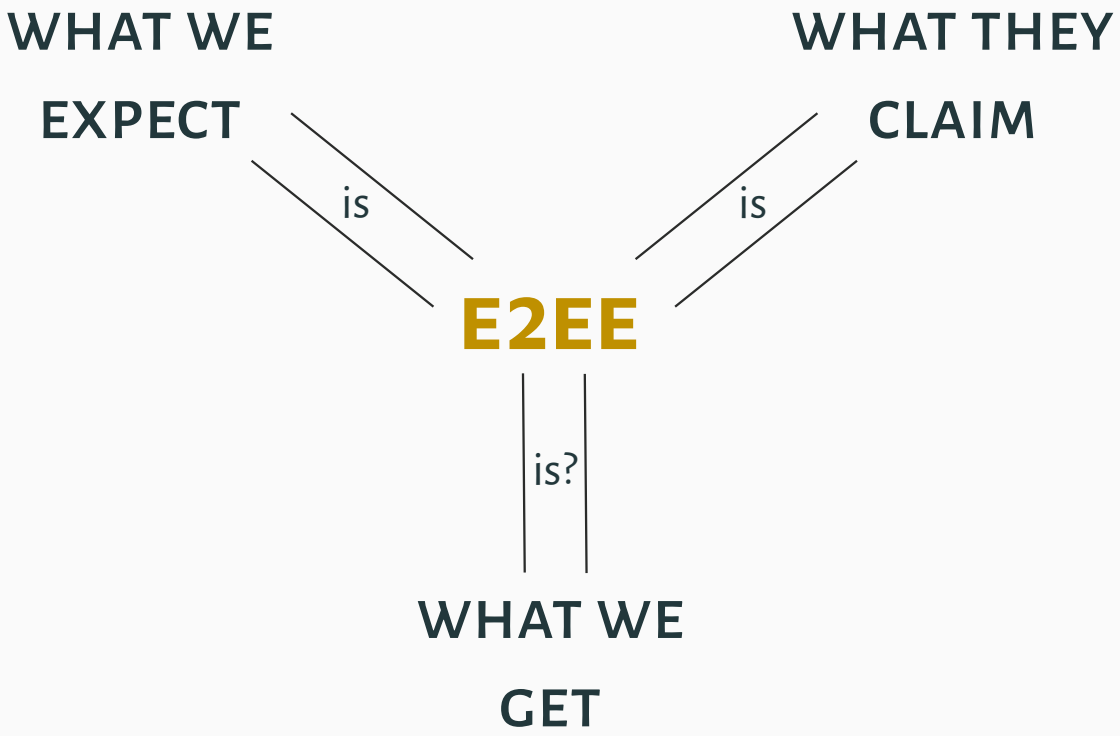
WHAT WE EXPECT

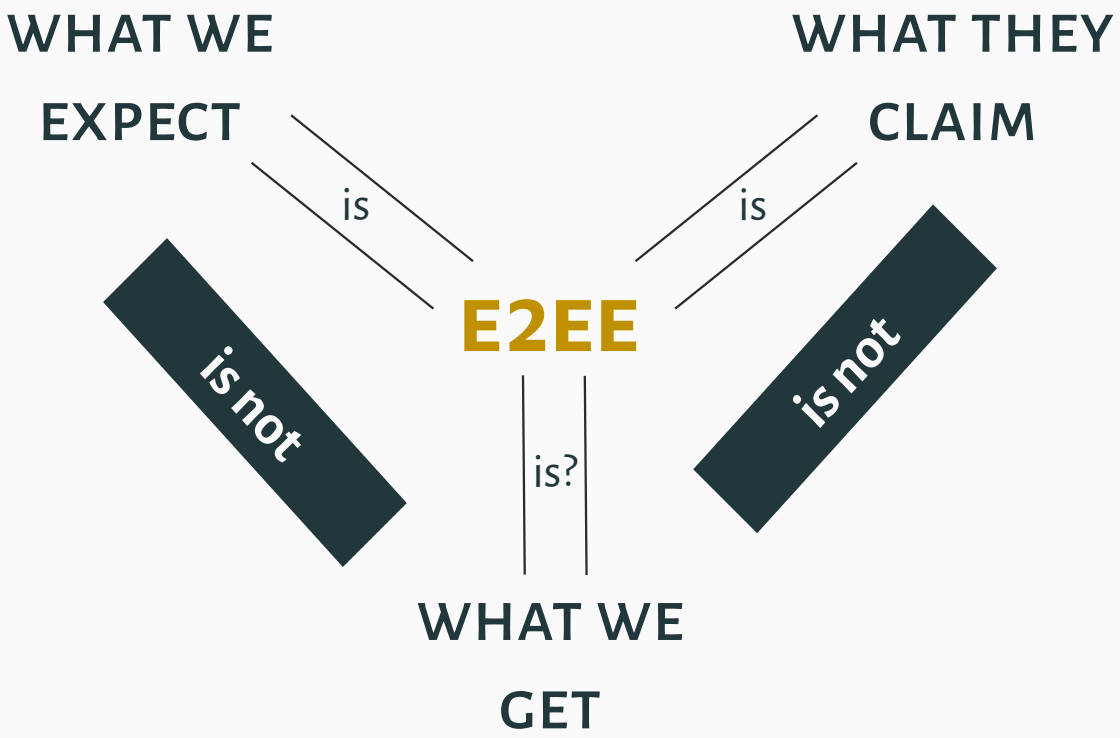
WHAT THEY CLAIM

is

is

E2EE


WHAT WE EXPECT
WHAT THEY CLAIM
is
is
E2EE
is?
WHAT WE GET

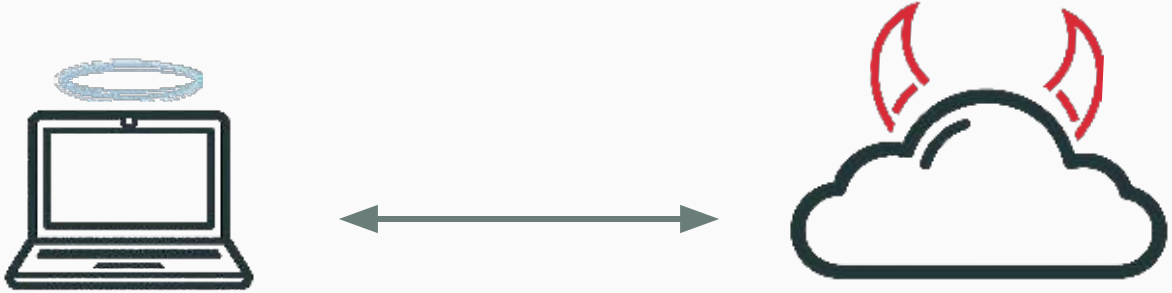

WHAT WE EXPECT
WHAT THEY CLAIM
is
is
E2EE
is not
is not
is?
WHAT WE GET

Security - What We Get

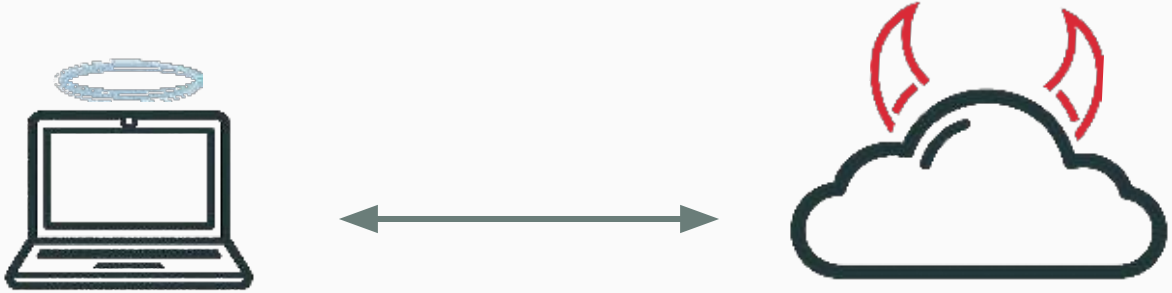
Security - What We Get

Security - What We Get

Security - What We Get



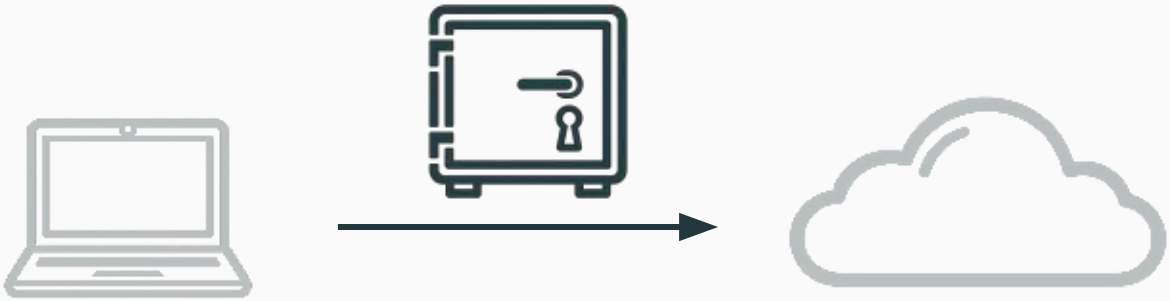
Security - What We Get



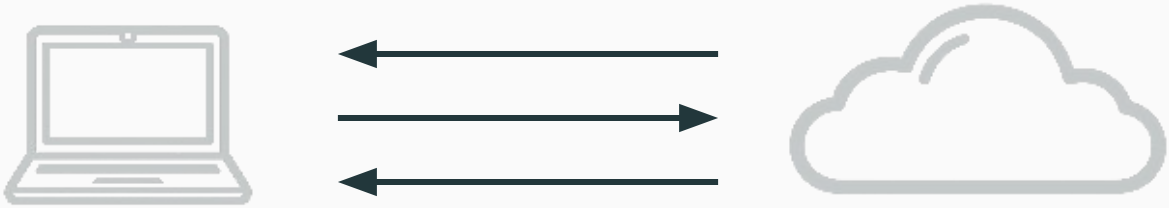
27 Attacks!

password managers are **badly** broken in the malicious server threat model

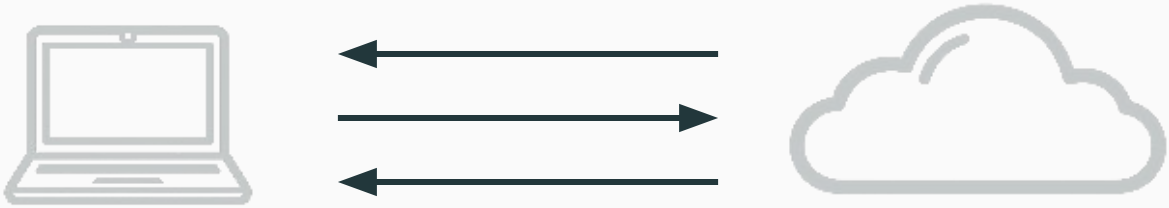
How did we get here?



How did we get here?



How did we get here?



Key Recovery

Partial Vault Sync

Sharing

Backwards Compatibility

Risky Features

Key Recovery

Partial Vault Sync

Sharing

Backwards Compatibility

Risky Features

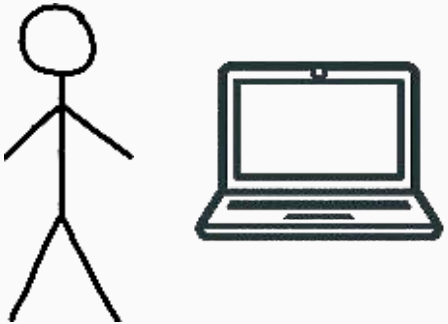
Key Recovery

Partial Vault Sync

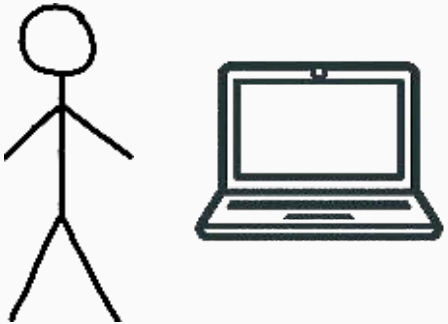
Sharing

Backwards Compatibility

Key Recovery Mechanism



Key Recovery Mechanism



Master Password:

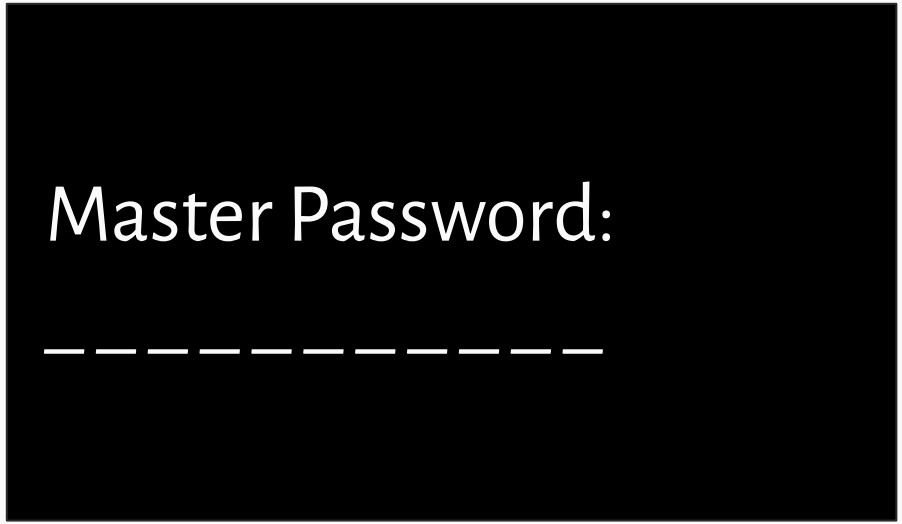
_ _ _ _ _ _ _ _ _ _ _ _ _

Key Recovery Mechanism

Master Password:

_ _ _ _ _ _ _ _ _ _ _ _ _

Key Recovery Mechanism



No master password ⇒ No access to vault

Key Recovery Mechanism

Enable Recovery

Key Recovery Mechanism

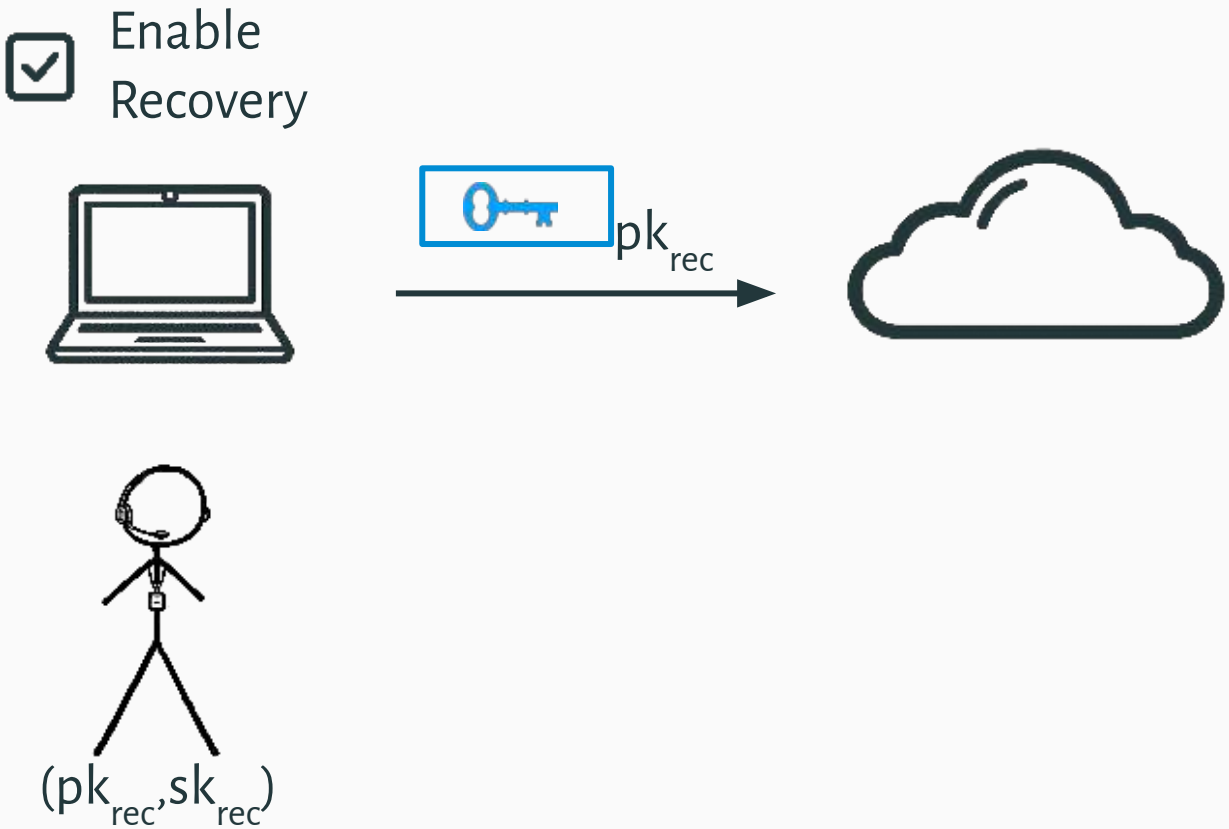
Enable Recovery

Key Recovery Mechanism

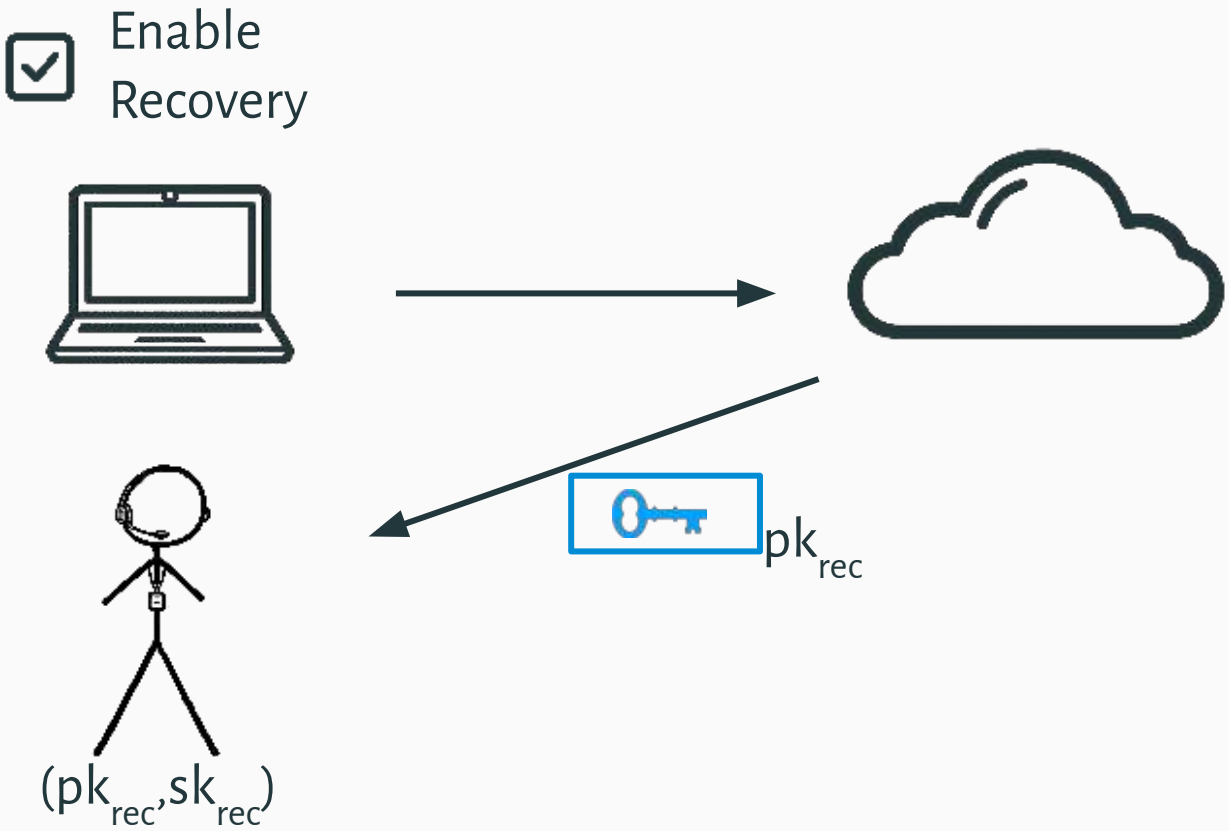
Enable Recovery

(pk_{rec}, sk_{rec})

Key Recovery Mechanism



Key Recovery Mechanism

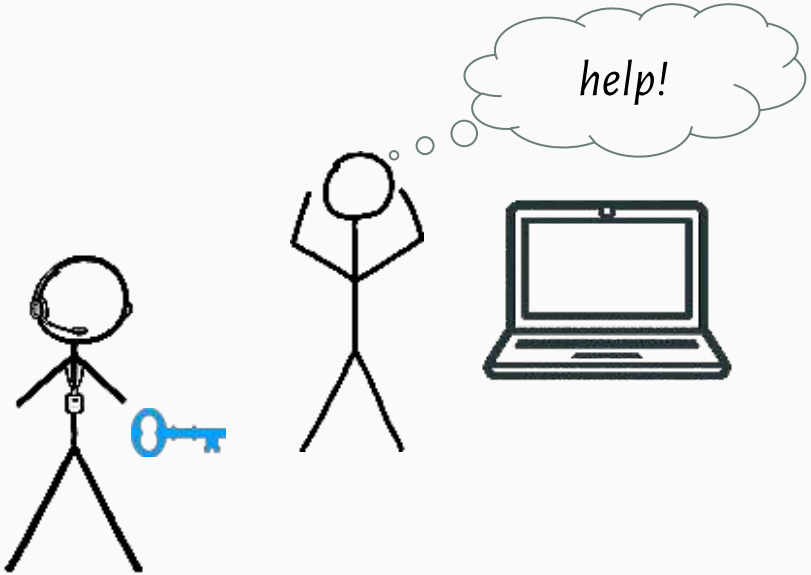


Key Recovery Mechanism

Master Password:

_ _ _ _ _ _ _ _ _ _ _ _ _

Key Recovery Mechanism



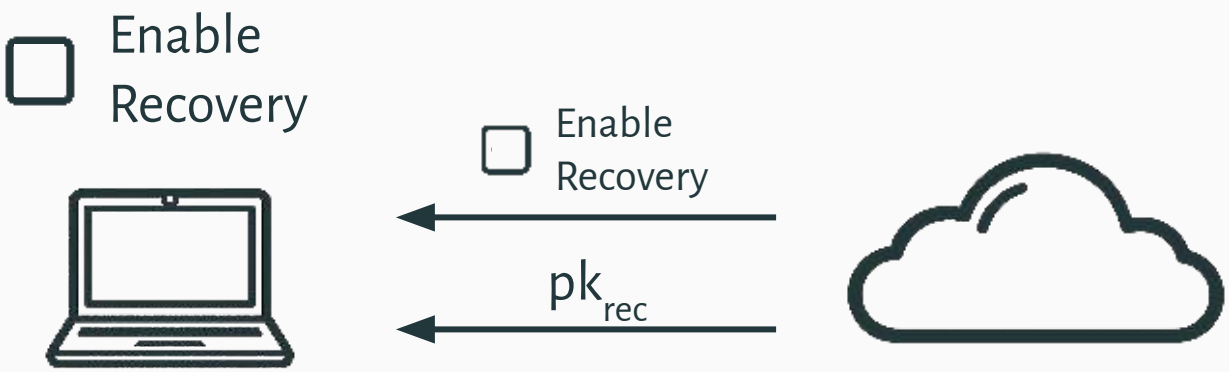
Master Password:

_ _ _ _ _ _ _ _ _ _ _ _ _

Key Recovery Mechanism

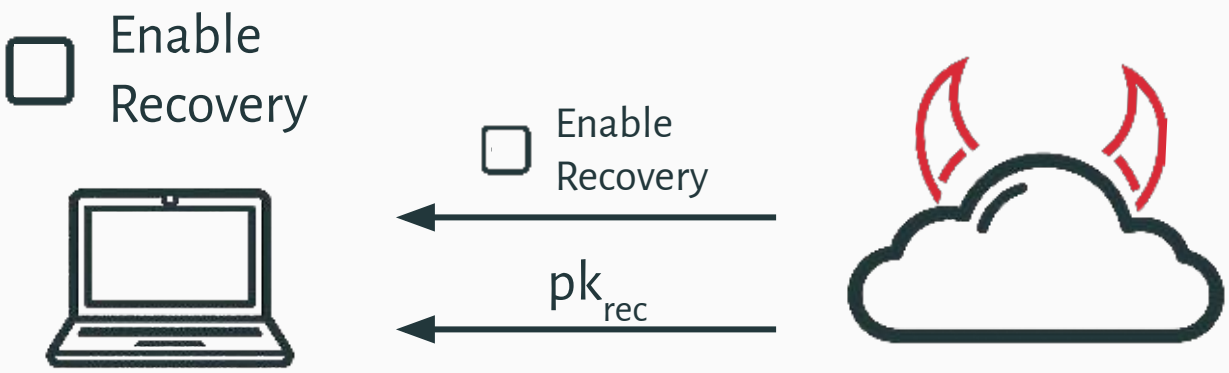
Enable Recovery

Key Recovery Mechanism



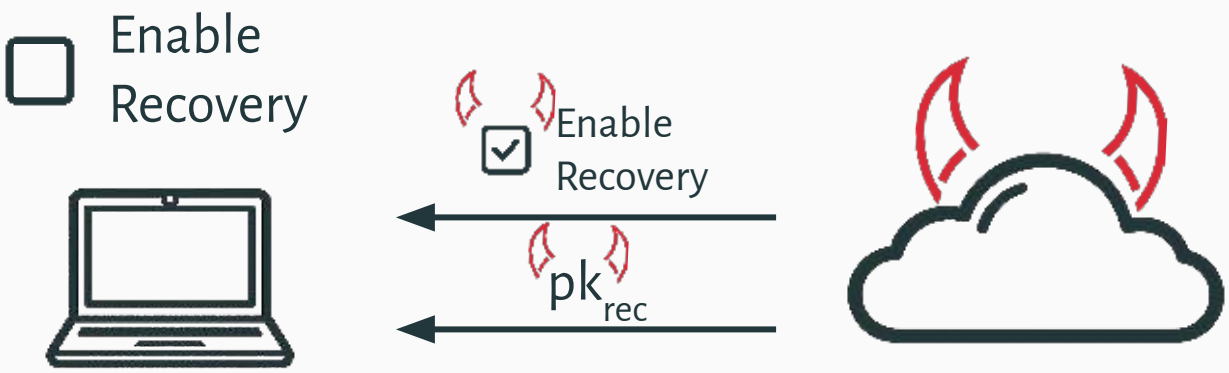
Key Recovery: Attack

LastPass LP01



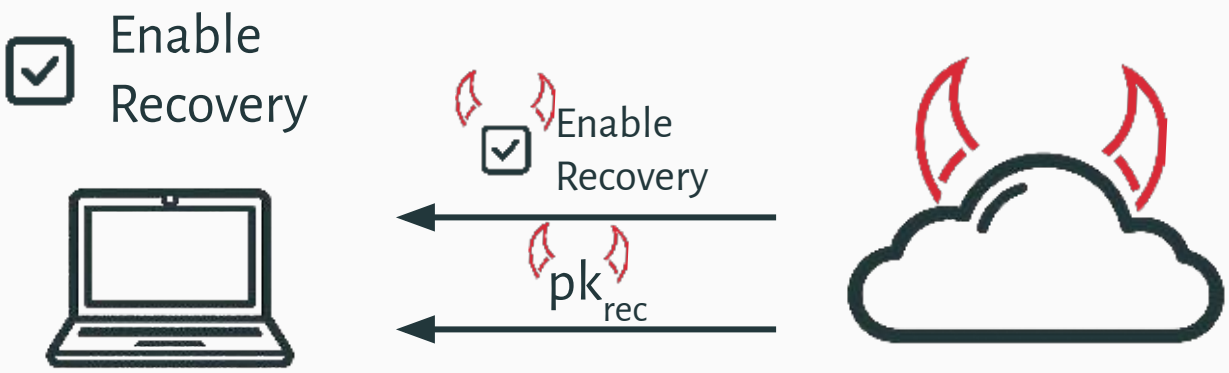
Key Recovery: Attack

LastPass LP01



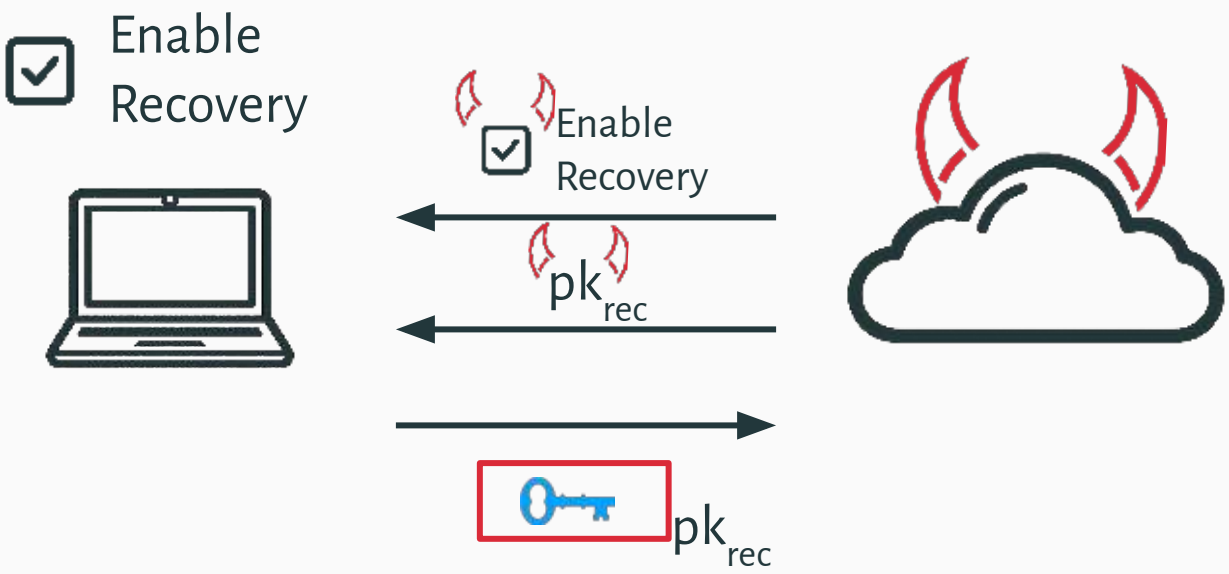
Key Recovery: Attack

LastPass LP01



Key Recovery: Attack

LastPass LP01



Risky Features

Key Recovery

Partial Vault Sync

Sharing

Backwards Compatibility

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

A Big Beautiful AEAD?

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com
```

```
Username: matteo
Password: pw1234
Url     : b.org
```

Item-level Encryption

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

LastPass

bitwarden

Field-level Encryption!

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

AES-CBC?!

LastPass•••|

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

LastPass

bitwarden

Field-level Encryption!

Partial Vault Sync

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

LastPass

bitwarden

Field-level Encryption!

No key separation!

Partial Vault Sync

LastPass

bitwarden

```
Username: matteo
Password: pw123
Url     : a.com

Username: matteo
Password: pw1234
Url     : b.org
```

Field-level Encryption!

No key separation!

Partial Vault Sync

LastPass

bitwarden

```
Username: matteo
Password: a.com
Url     : pw123

Username: matteo
Password: pw1234
Url     : b.org
```

Field-level Encryption!

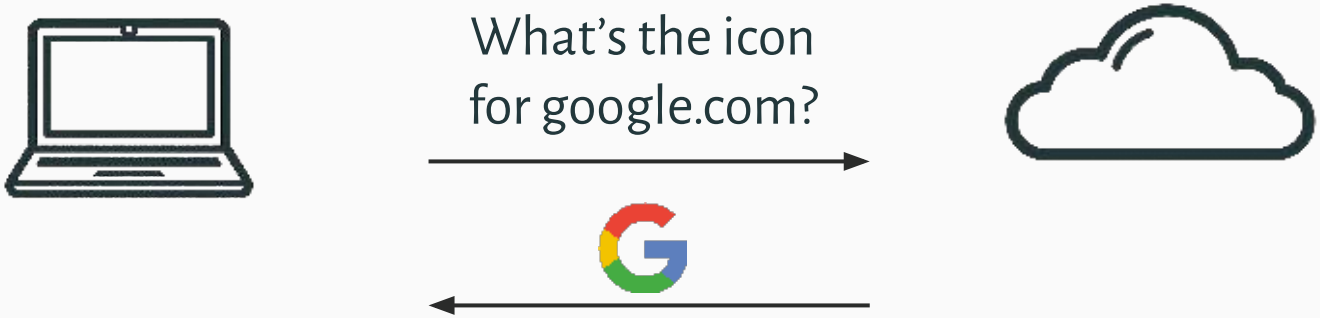
No key separation!

Icon Fetching

```
Username: matteo
Password: pw.1234
Url     : google.com
```

Icon Fetching

```
Username: matteo
Password: pw.1234
Url     : google.com
```



Partial Vault Sync + Icon Fetching

```
Username: matteo
Password: pw.1234
Url     : google.com
```

Partial Vault Sync + Icon Fetching

```
Username: matteo
Password: google.com
Url     : pw.1234
```

Partial Vault Sync + Icon Fetching

```
Username: matteo
Password: google.com
Url     : pw.1234
```

What's the icon for `pw.1234`?

Partial Vault Sync + Icon Fetching

```
Username: matteo
Password: google.com
Url     : pw.1234
```

What's the icon for `pw.1234`?

Partial Vault Sync + Icon Fetching

LastPass LP03

bitwarden BW06*

```
Username: matteo
Password: google.com
Url     : pw.1234
```

What's the icon for pw.1234?

Partial Vault Sync + Icon Fetching

LastPass LP03

bitwarden BW06*

```
Username: matteo
Password: google.com
Url     : pw.1234
```

What's the icon for pw.1234?

*: password must contain a ".", no "!"

Risky Features

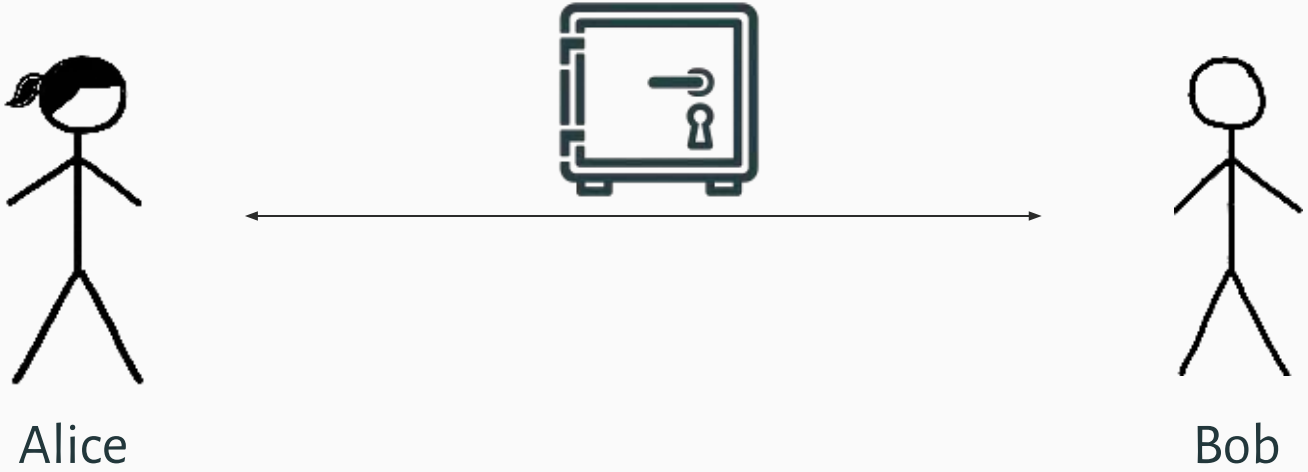
Key Recovery

Partial Vault Sync

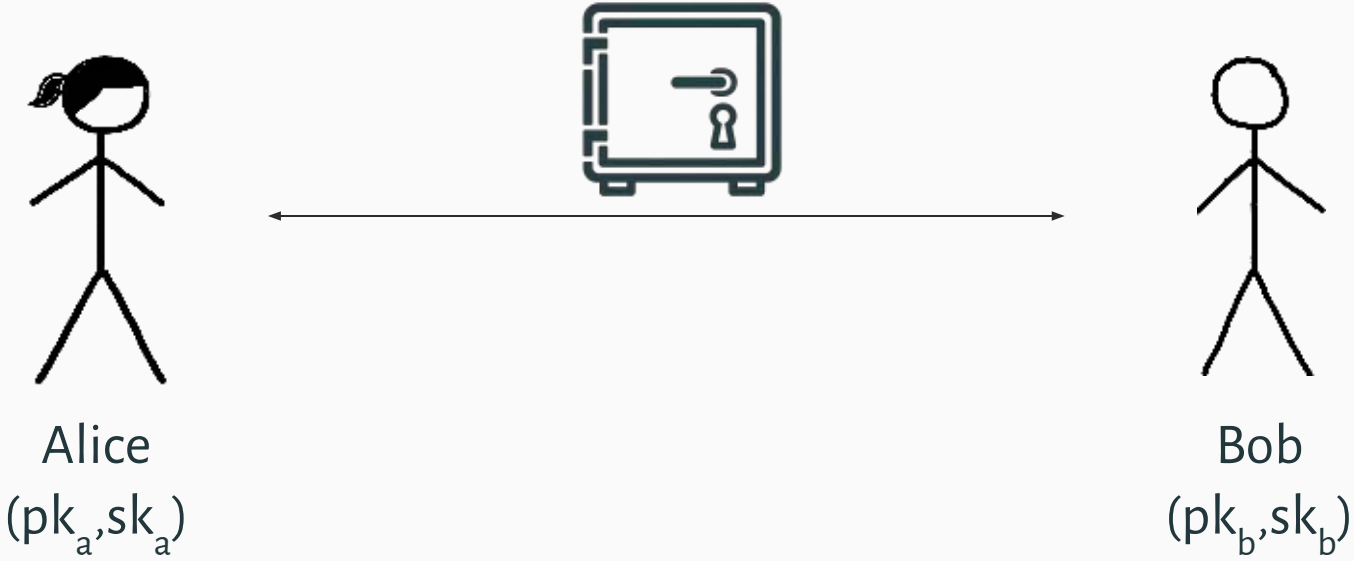
Sharing

Backwards Compatibility

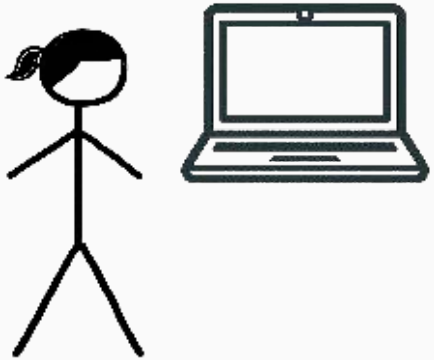
Sharing



Sharing

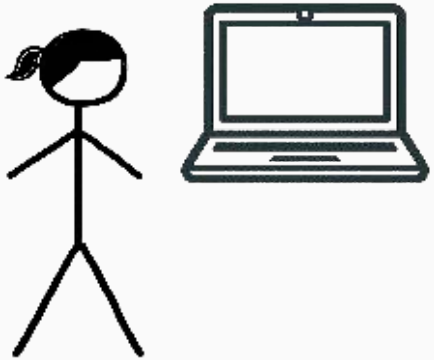


Sharing



What's bob's public key?

Sharing



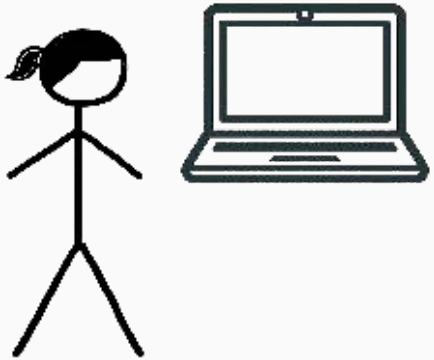
What's bob's public key?

$\longrightarrow$

pk_b

$\longleftarrow$

Sharing



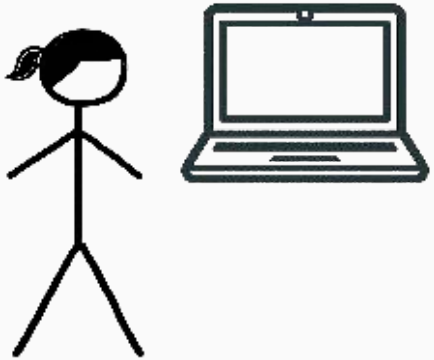
What's bob's public key?

$\longrightarrow$

pk_b

$\longleftarrow$

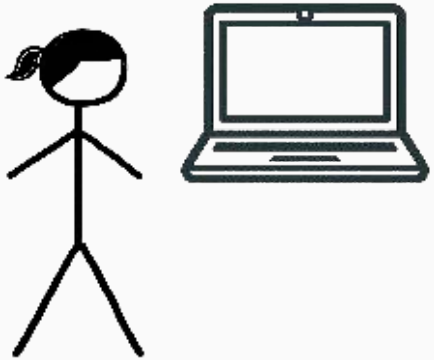
Sharing



What's bob's public key?

pk_b

Sharing



What's bob's public key?

pk_b

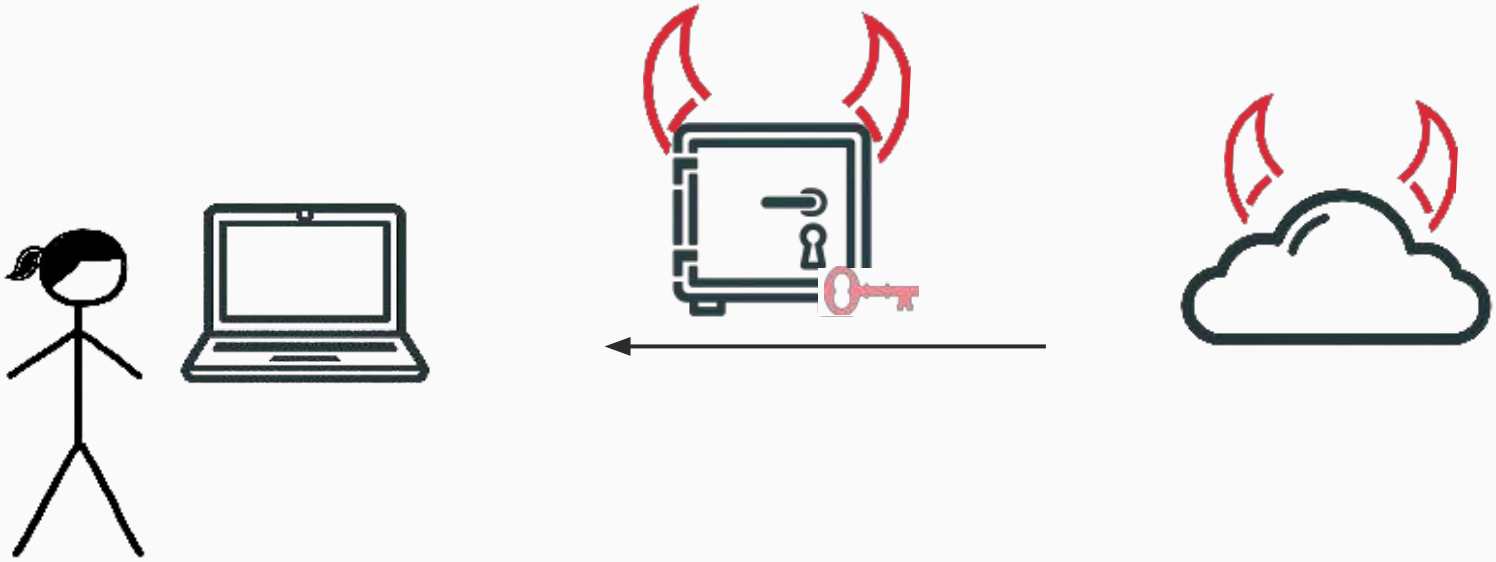
LastPass

DASHLANE

bitwarden

1Password

Sharing



1Password

Risky Features

Key Recovery

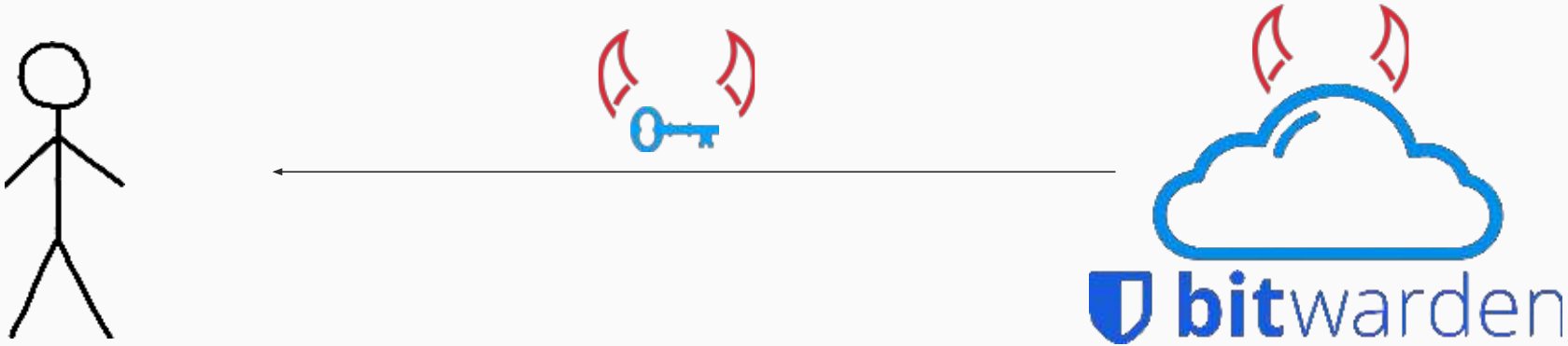
Partial Vault Sync

Sharing

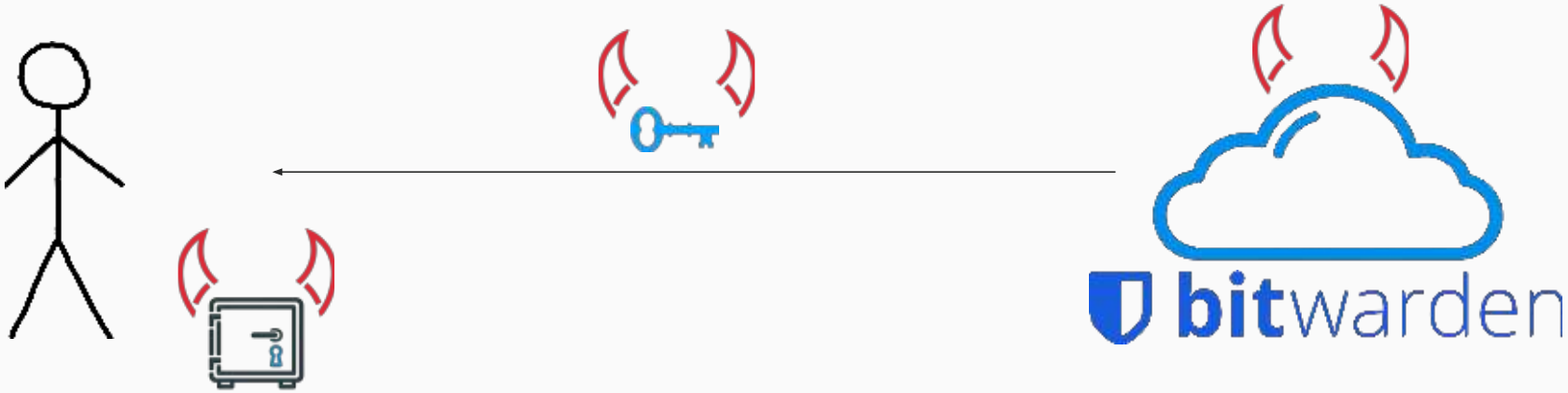
Backwards Compatibility

The Heisenberg Attack

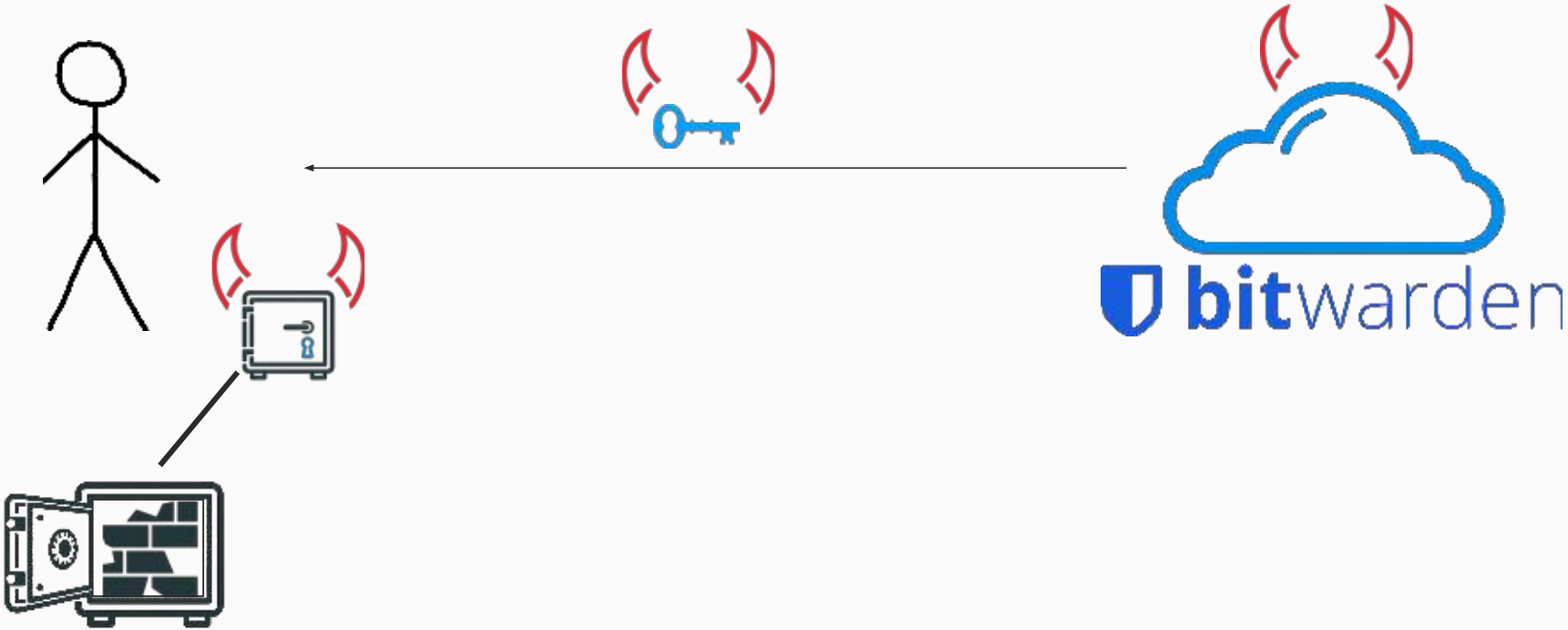
The Heisenberg Attack



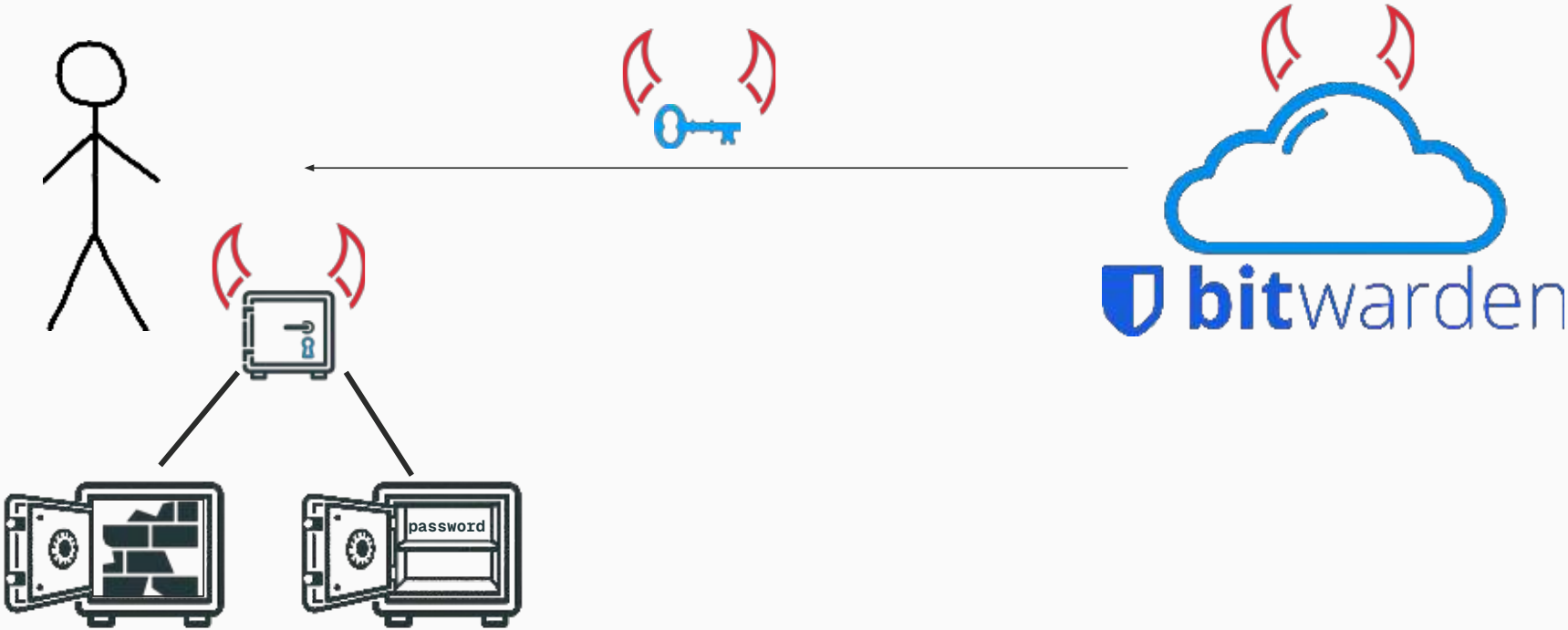
The Heisenberg Attack



The Heisenberg Attack



The Heisenberg Attack



Backwards
Compatibility

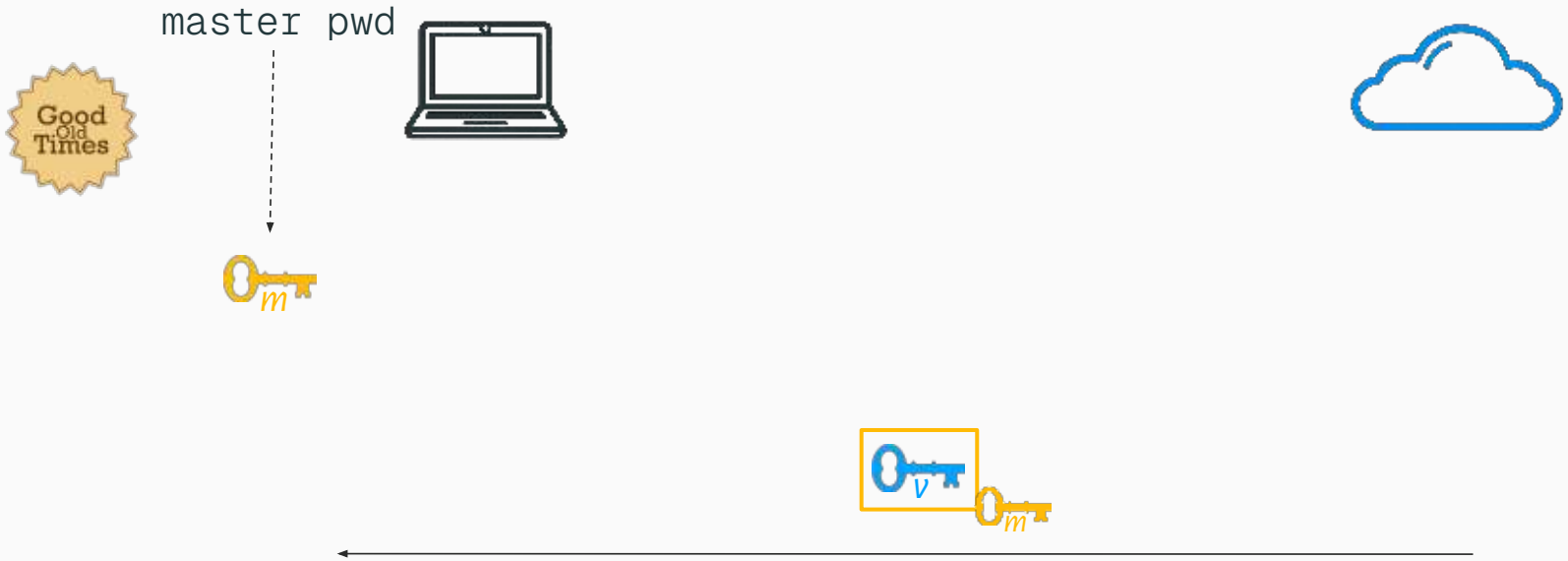
Login in the good old times

Login in the good old times

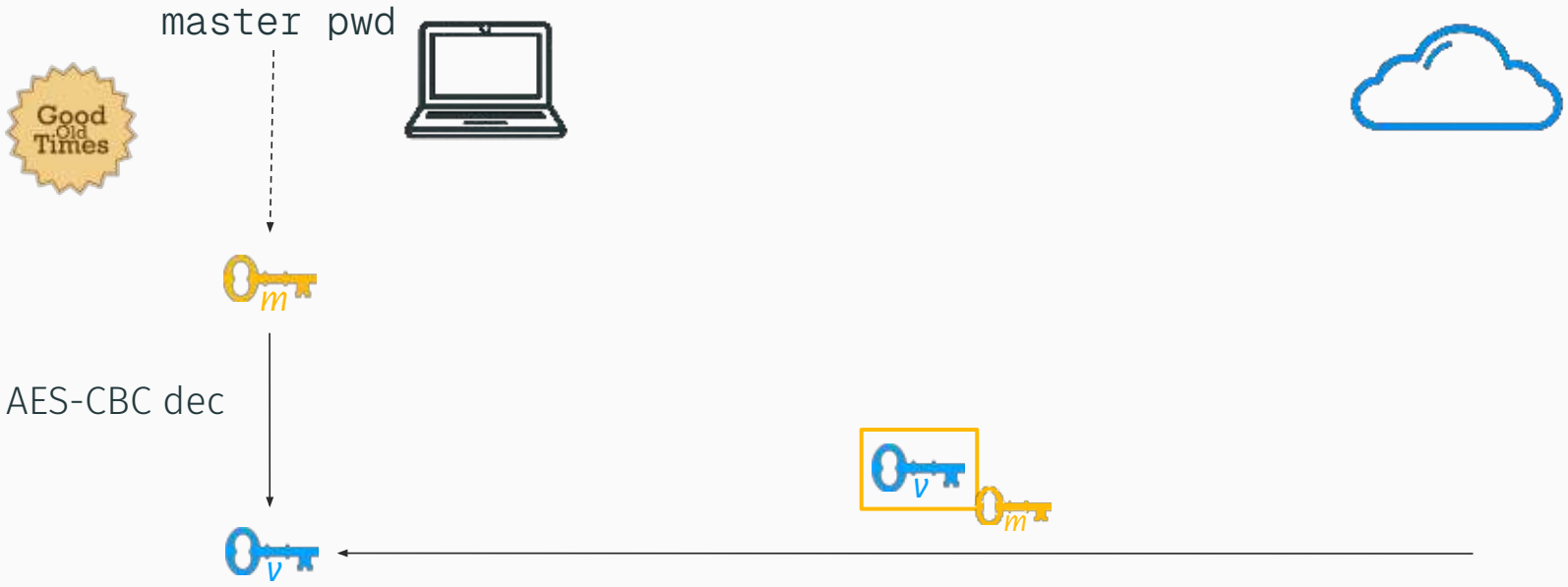
master pwd

Login in the good old times

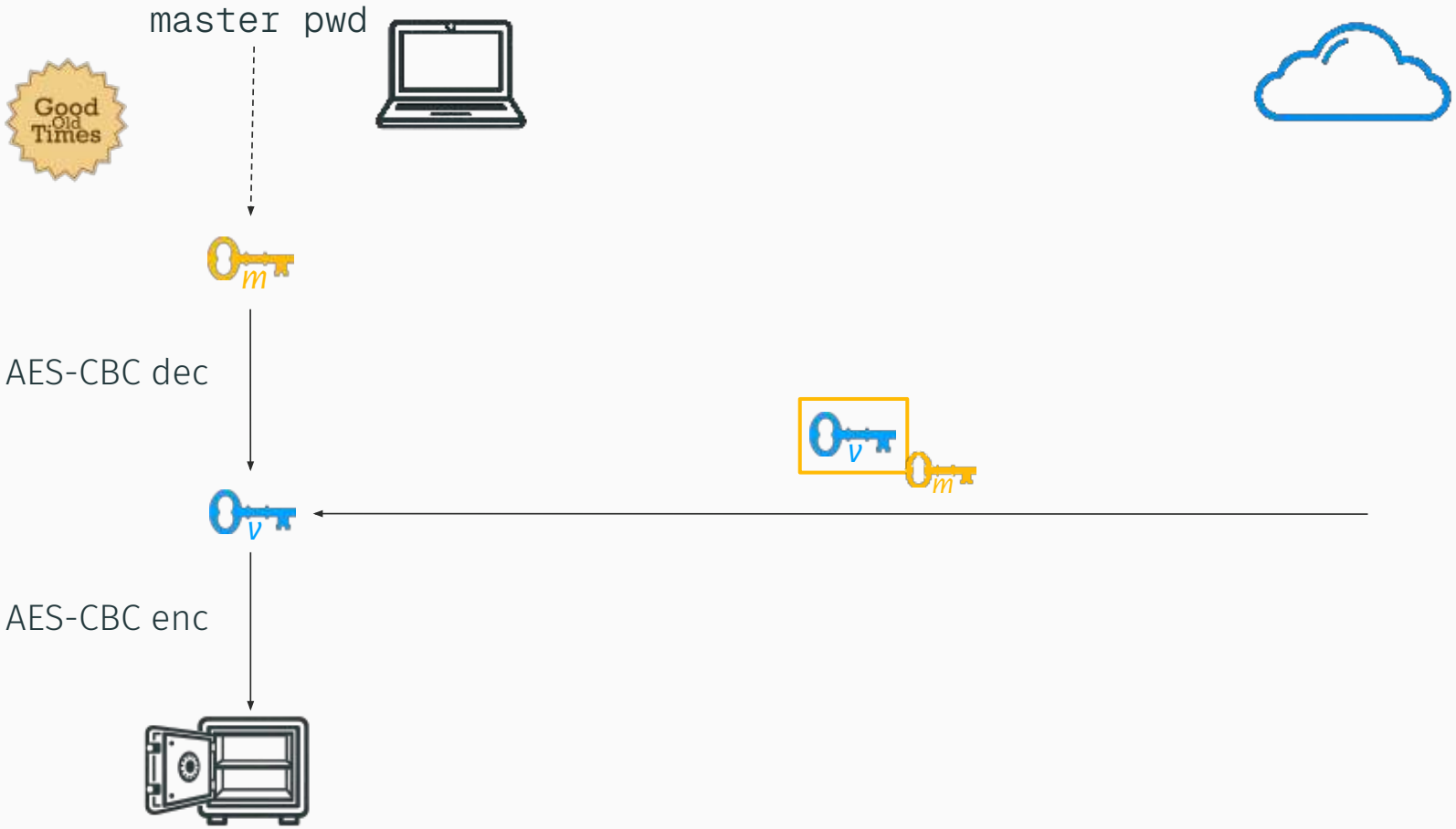
Login in the good old times



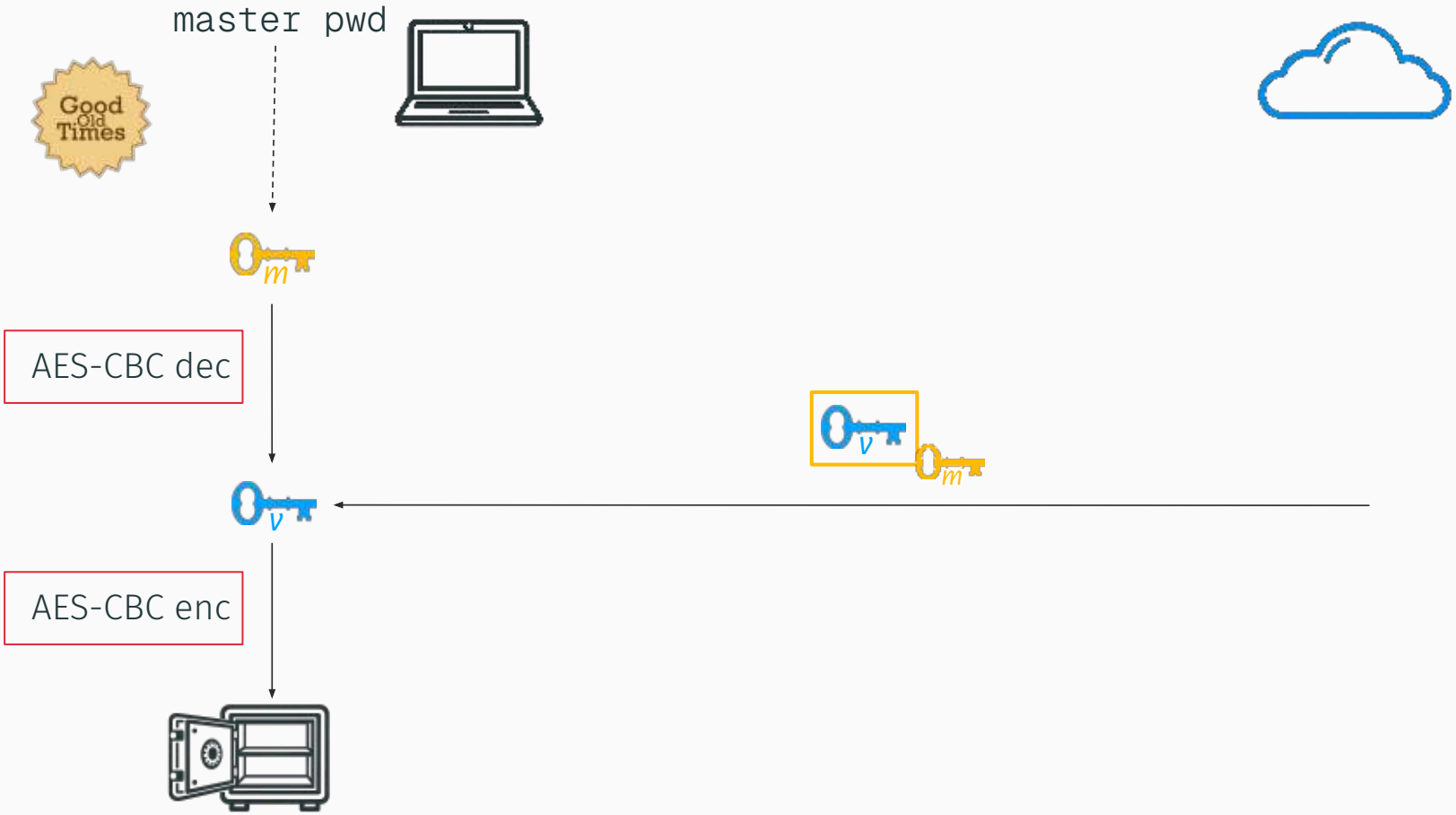
Login in the good old times



Login in the good old times



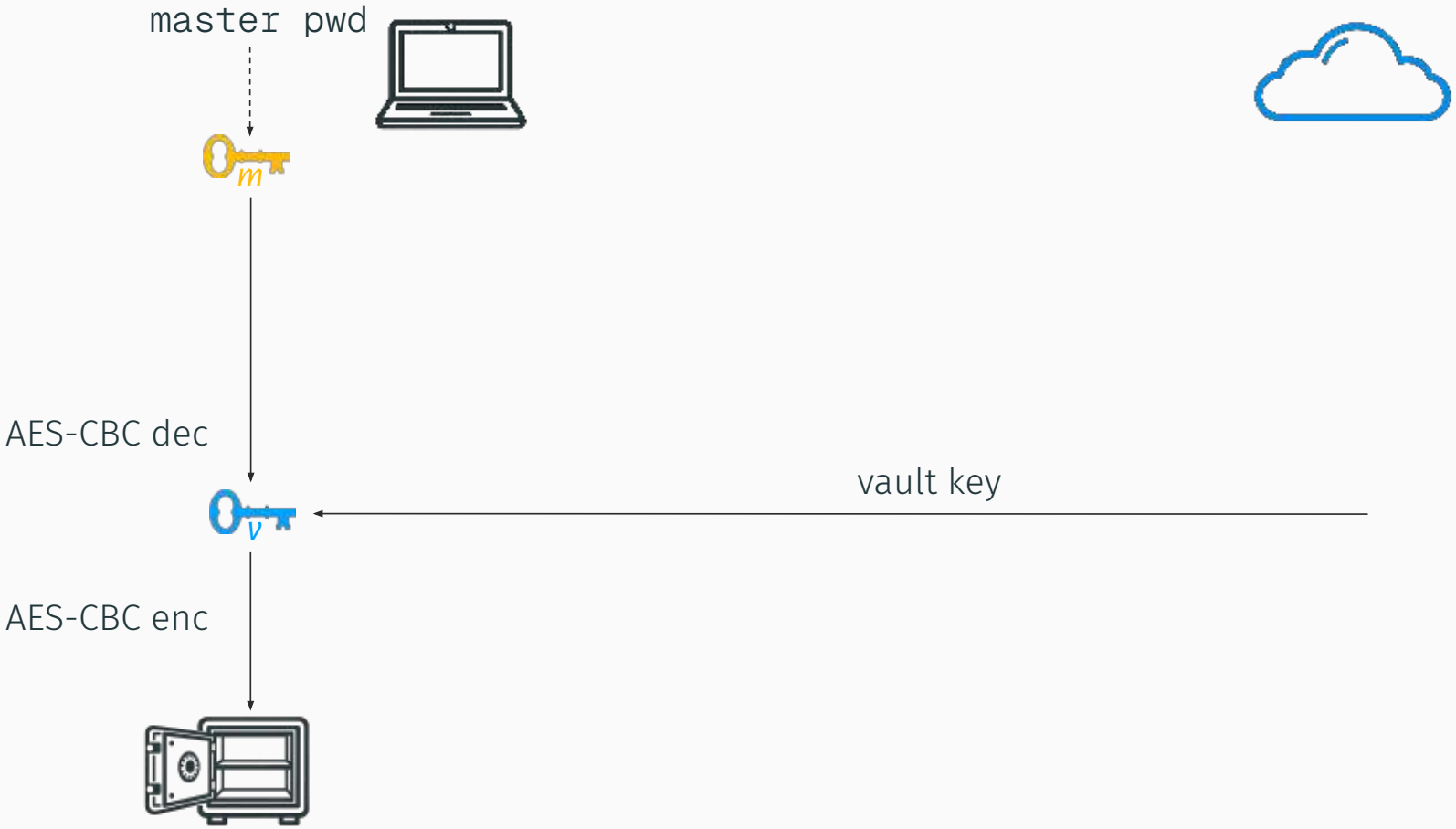
Login in the good old times



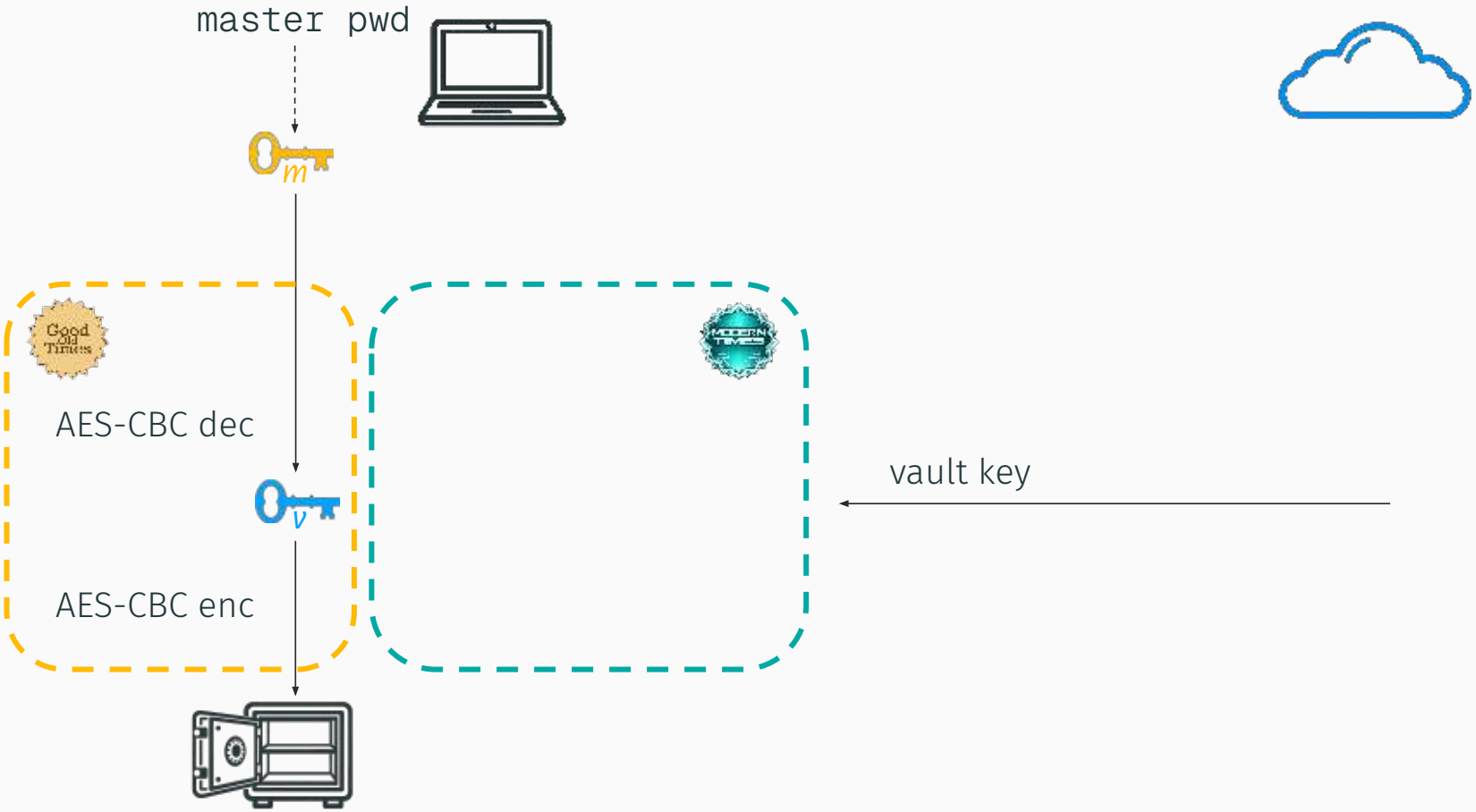
Good
Old
Times

MODERN
TIMES

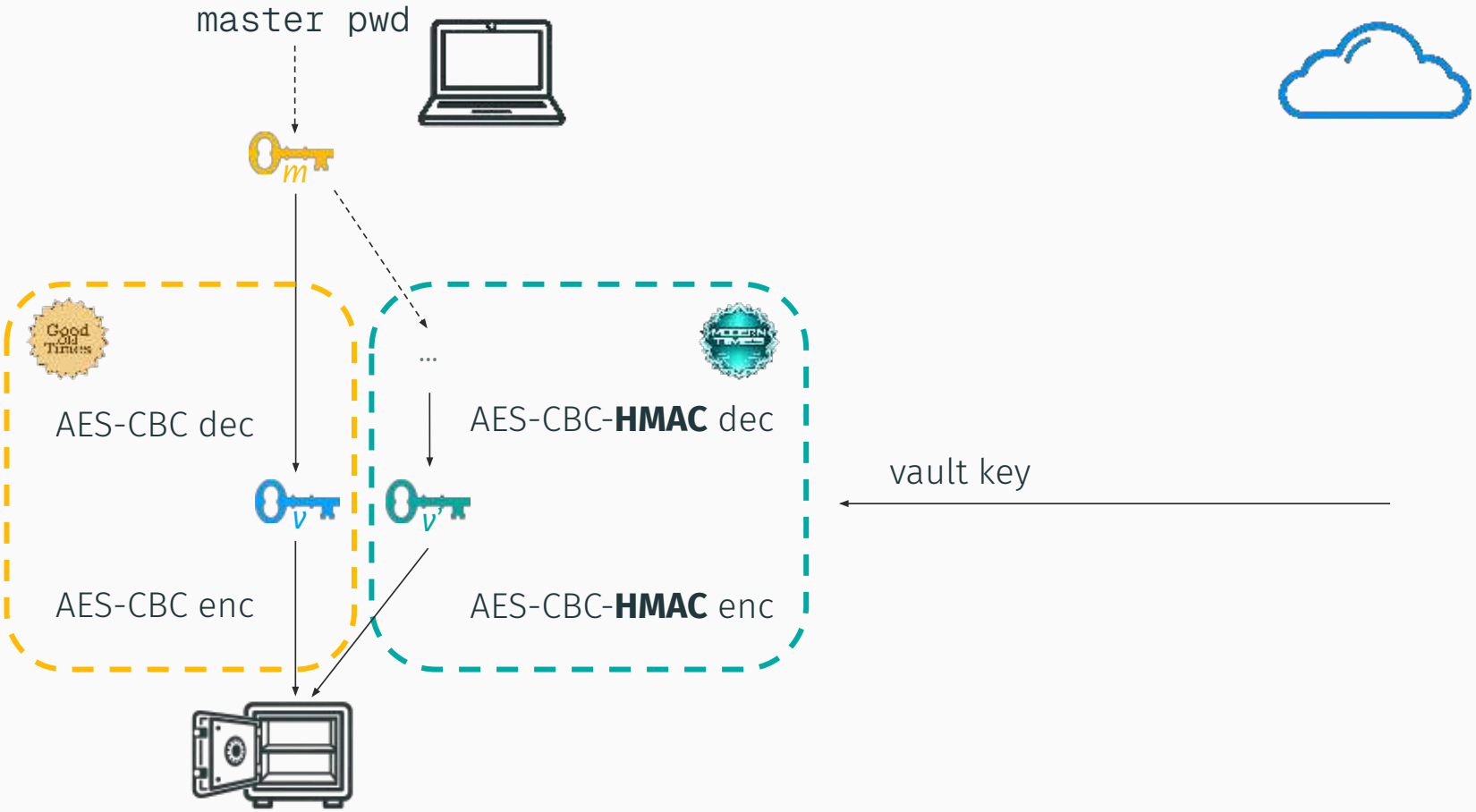
Old vs Modern times



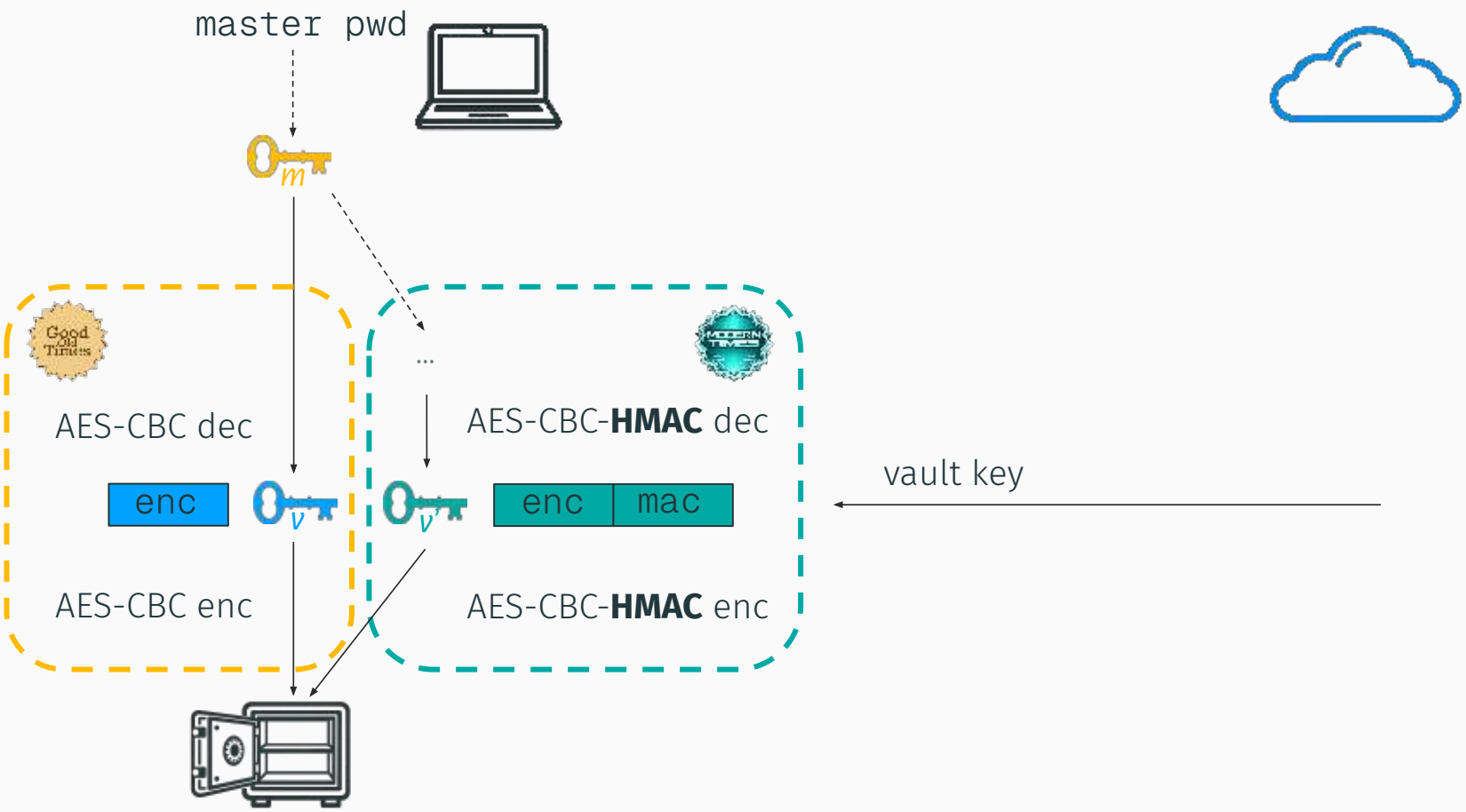
Old vs Modern times



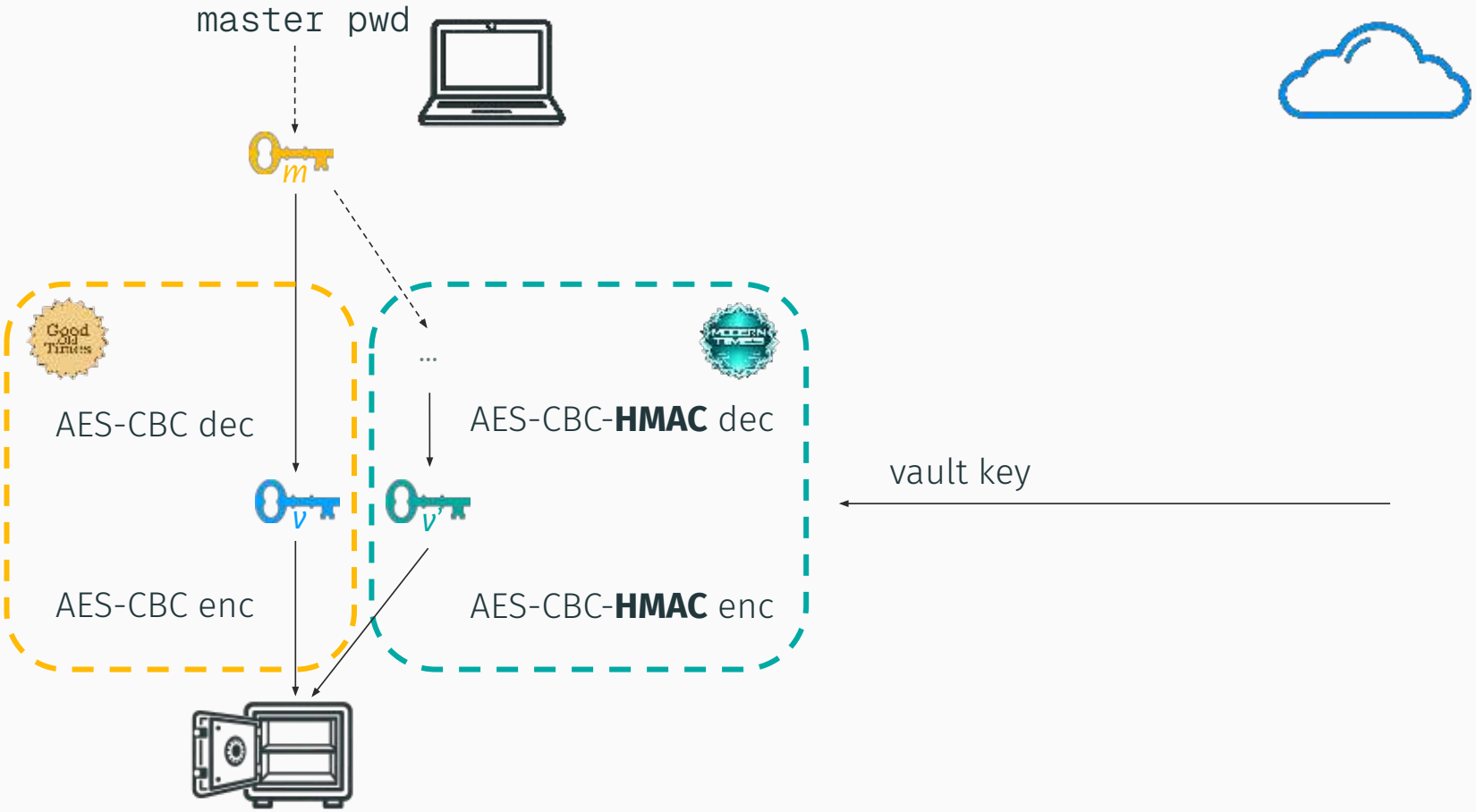
Old vs Modern times



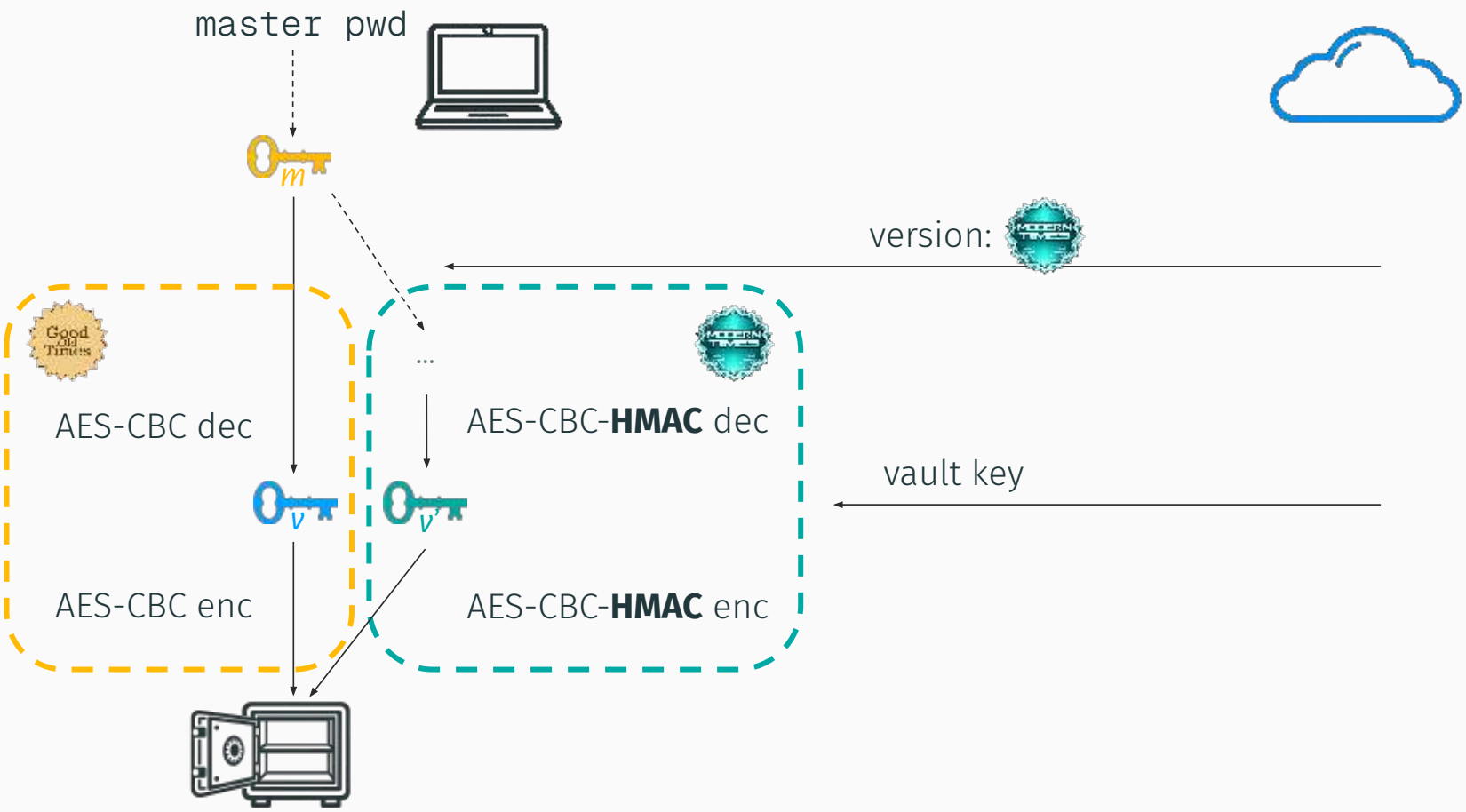
Old vs Modern times



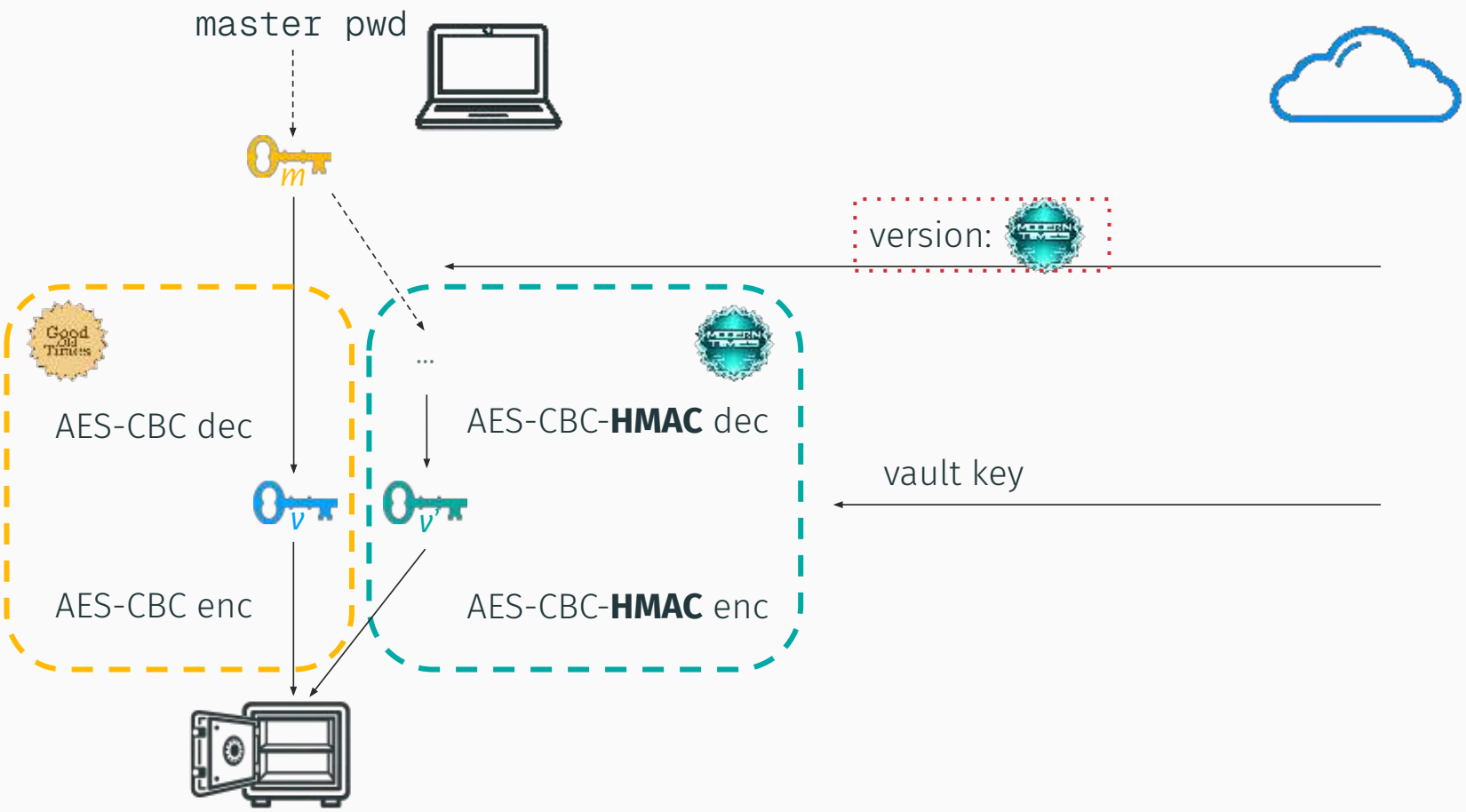
Which version to choose?



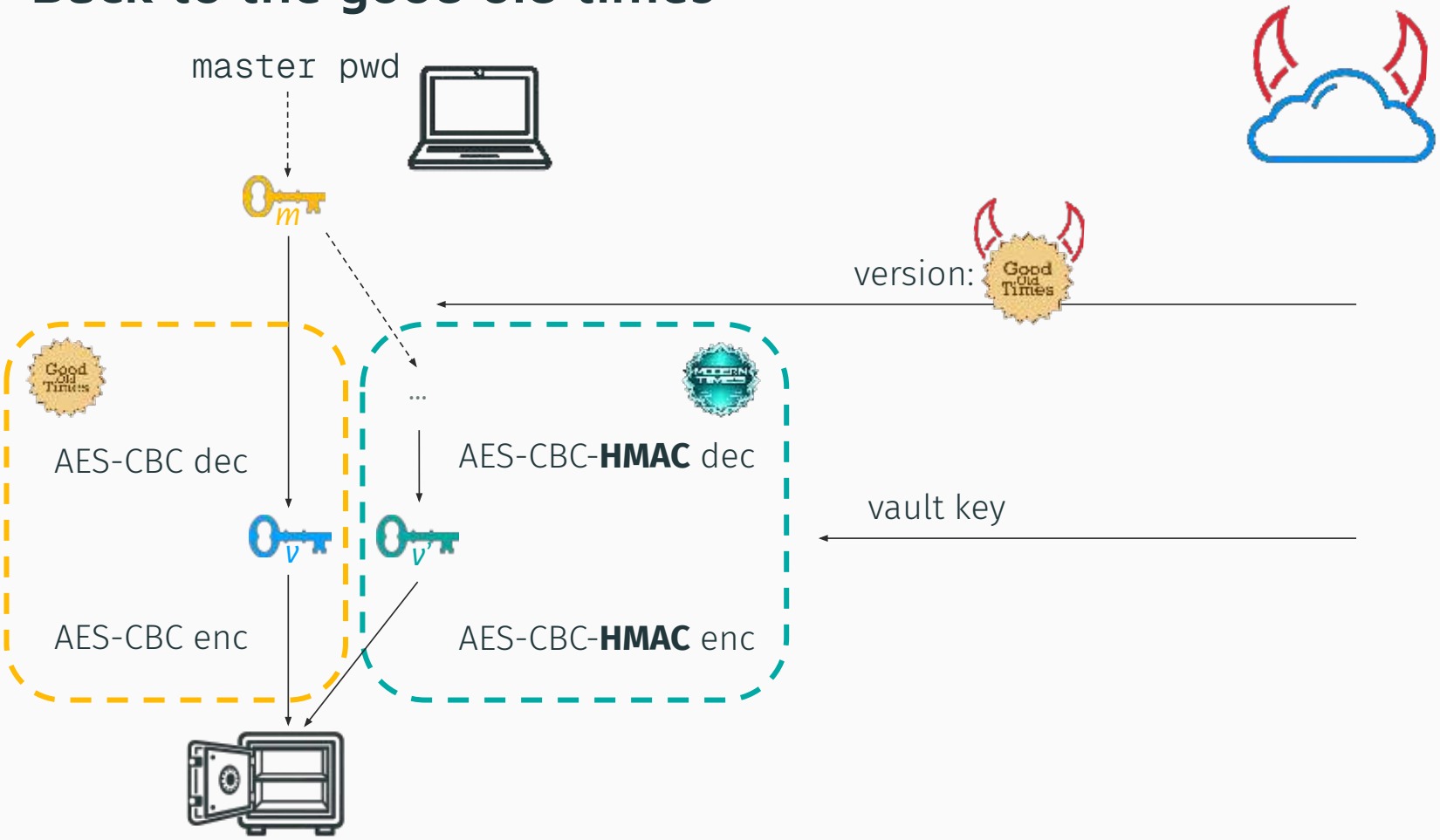
Which version to choose?



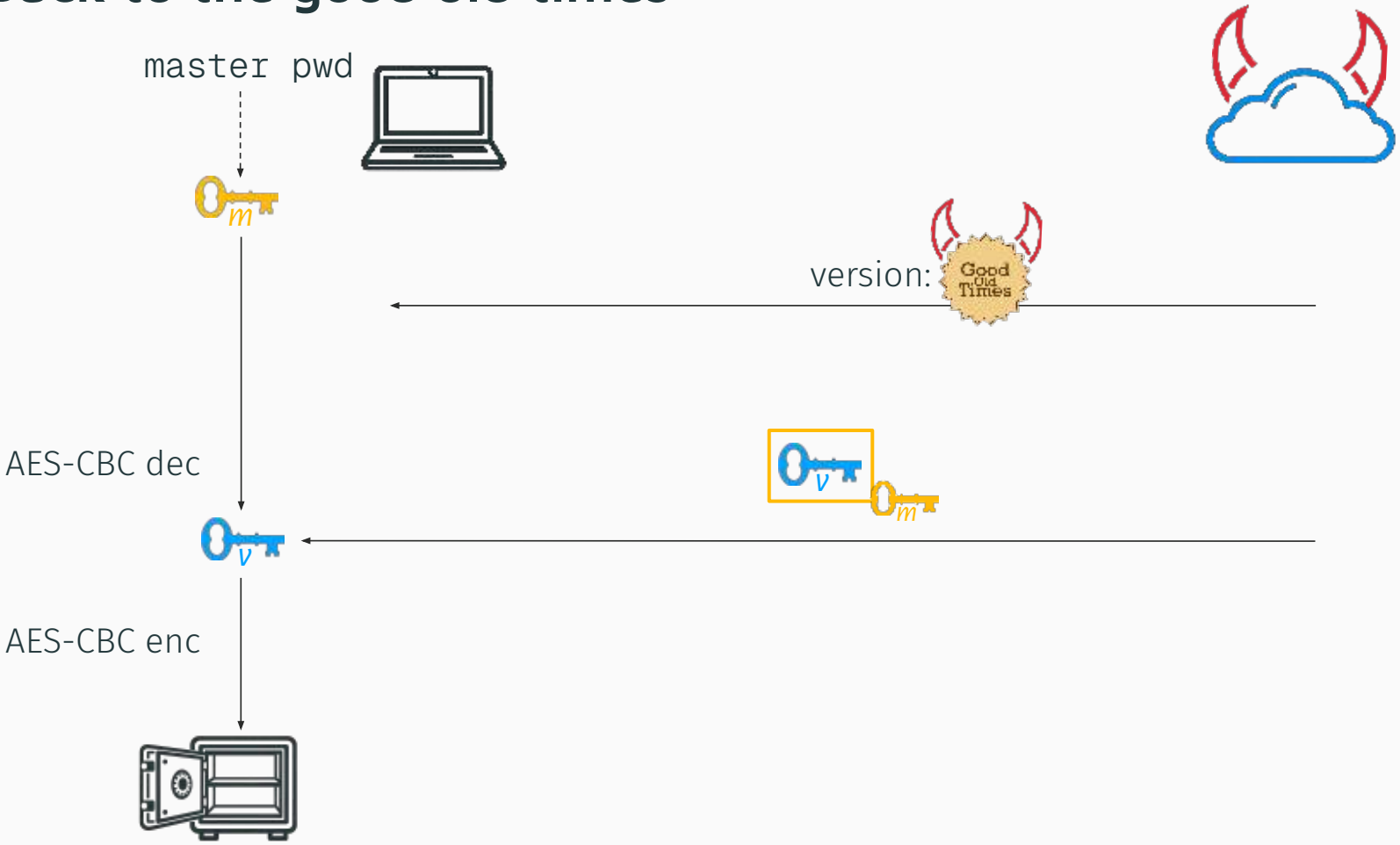
Which version to choose?



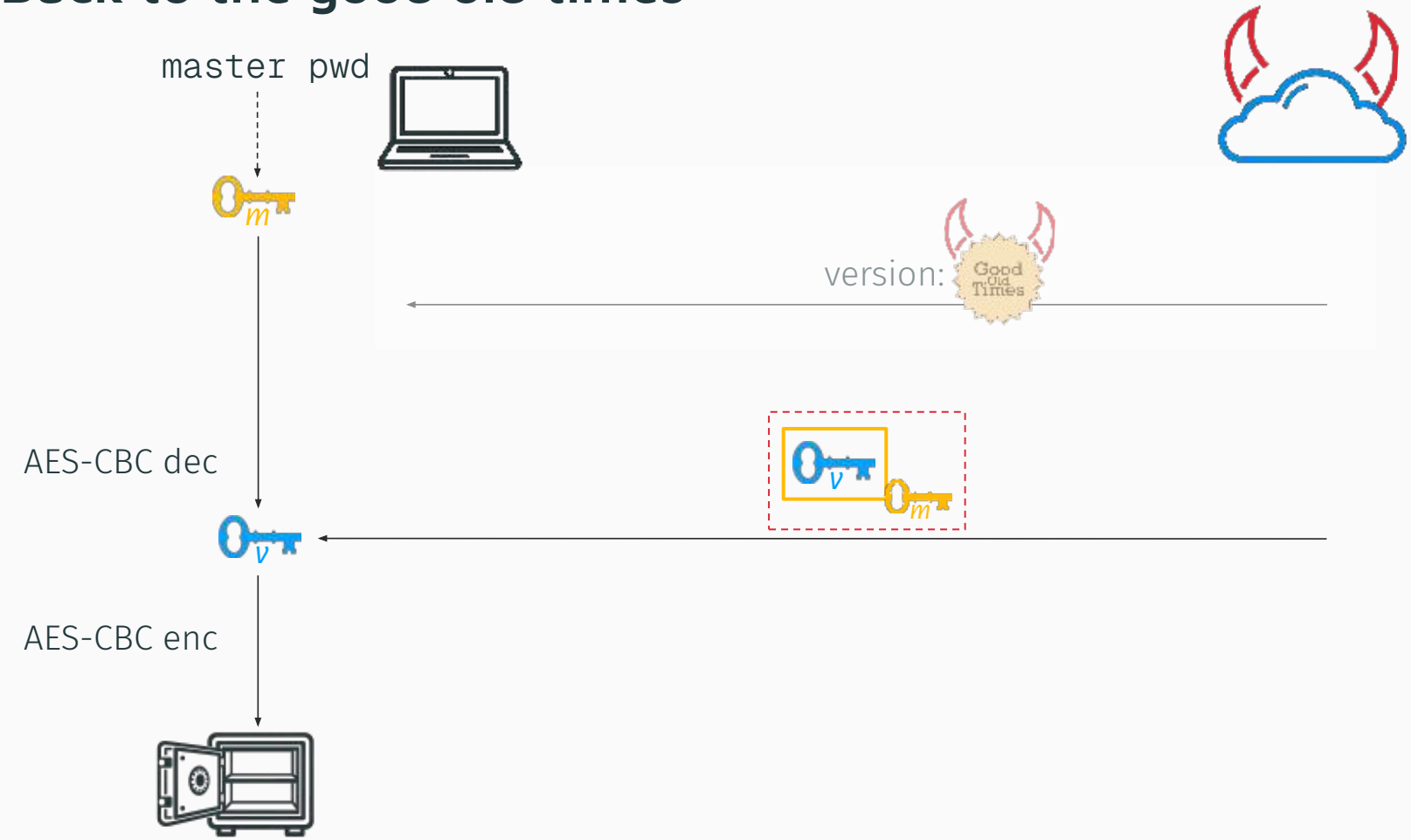
Back to the good old times



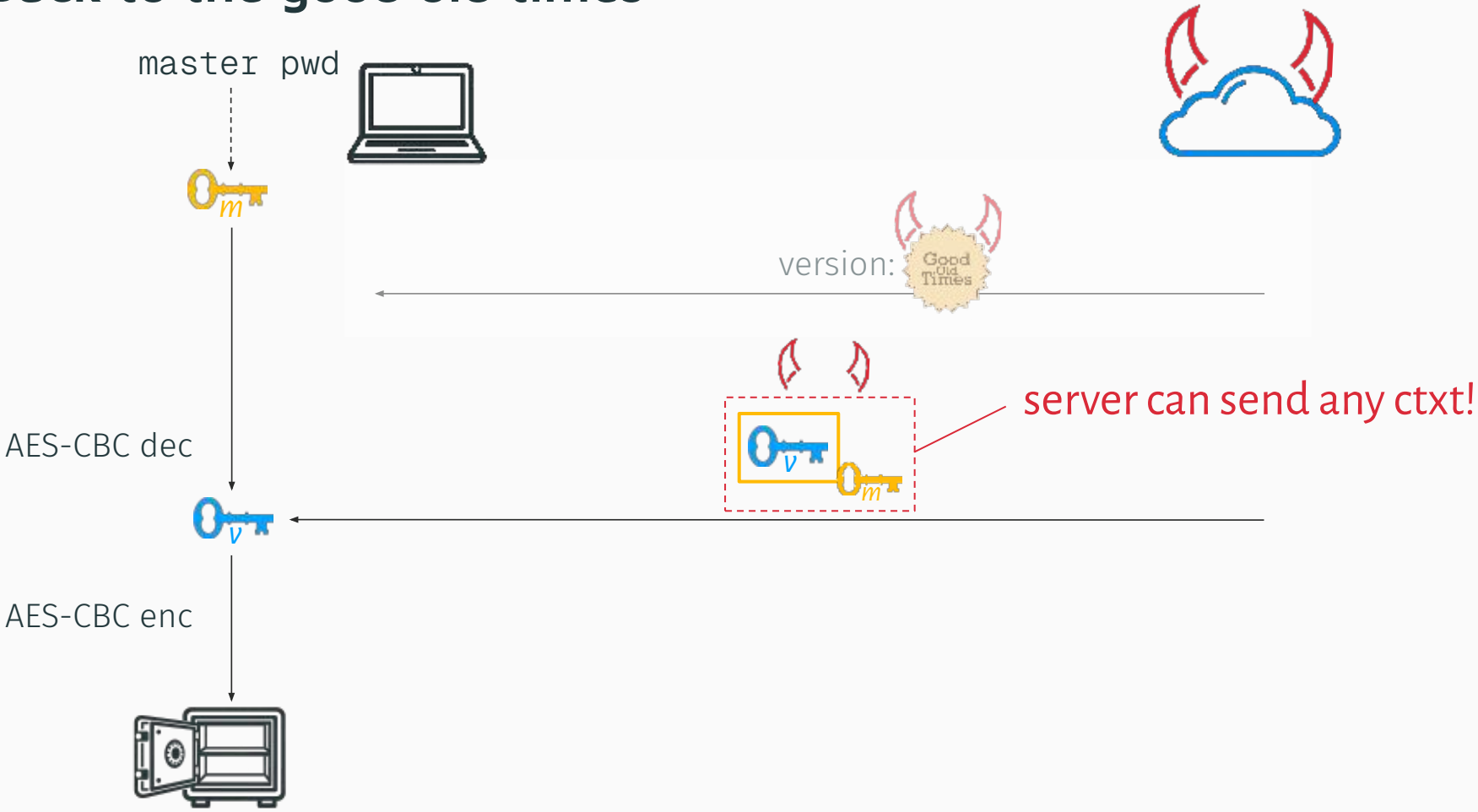
Back to the good old times



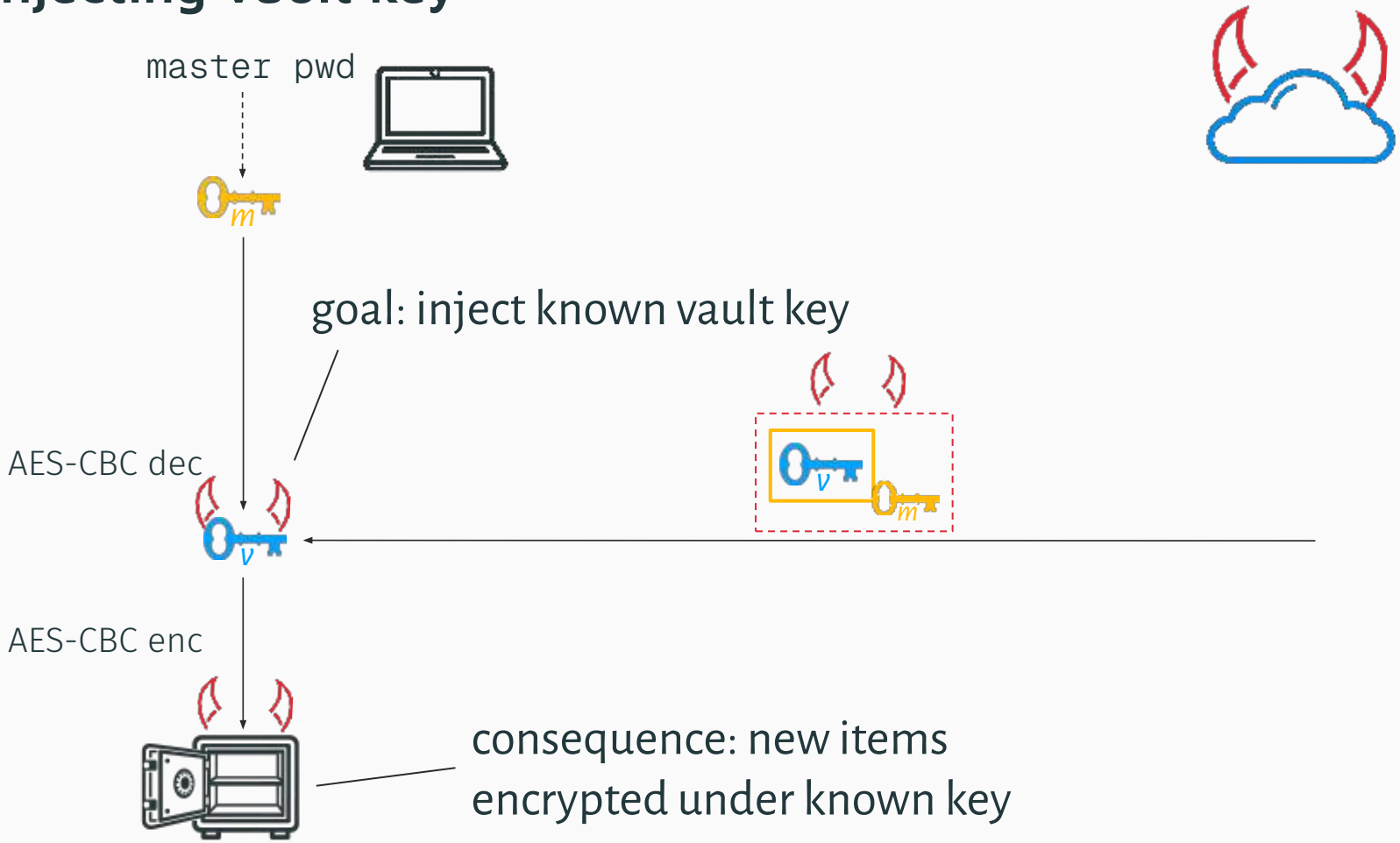
Back to the good old times



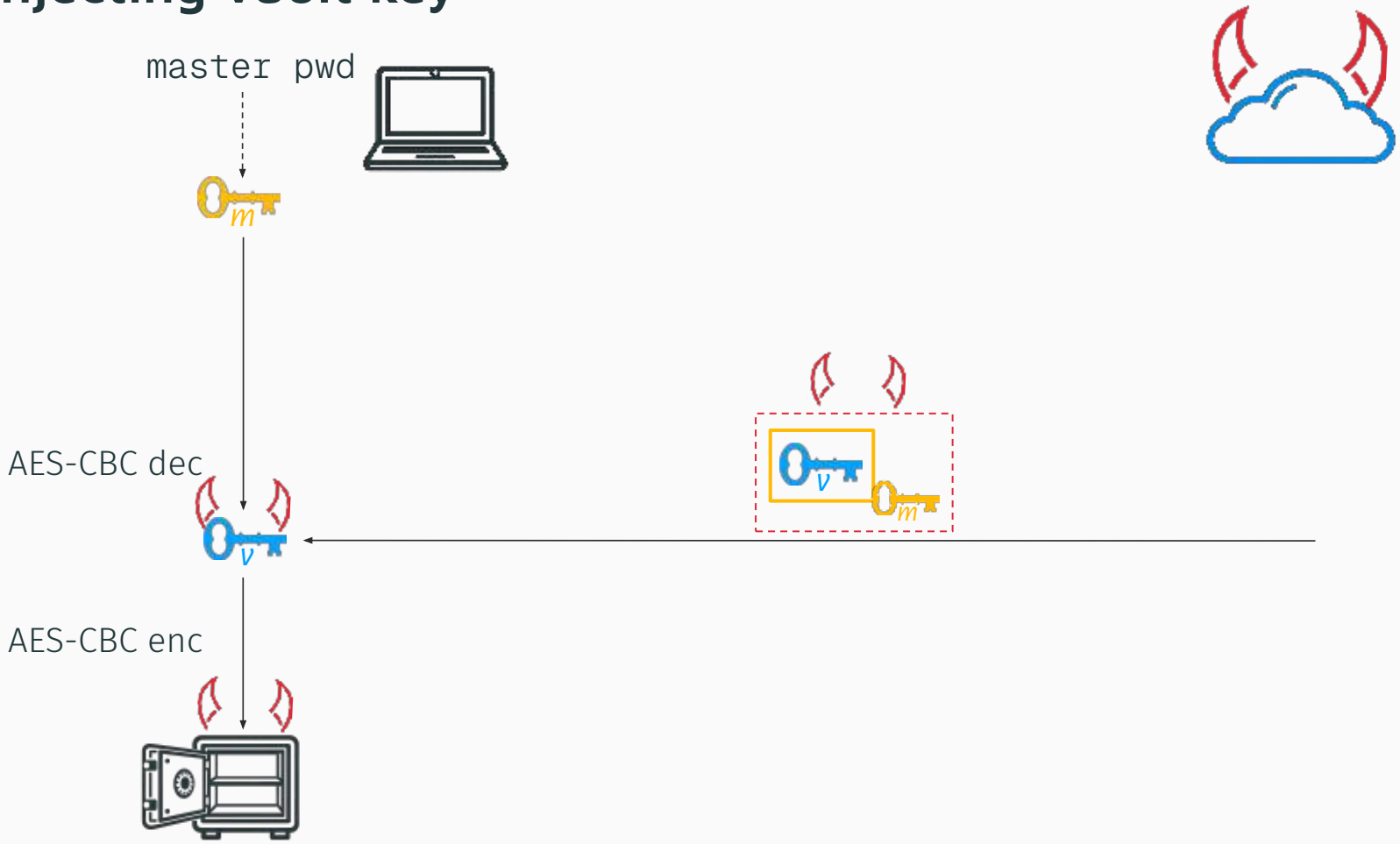
Back to the good old times



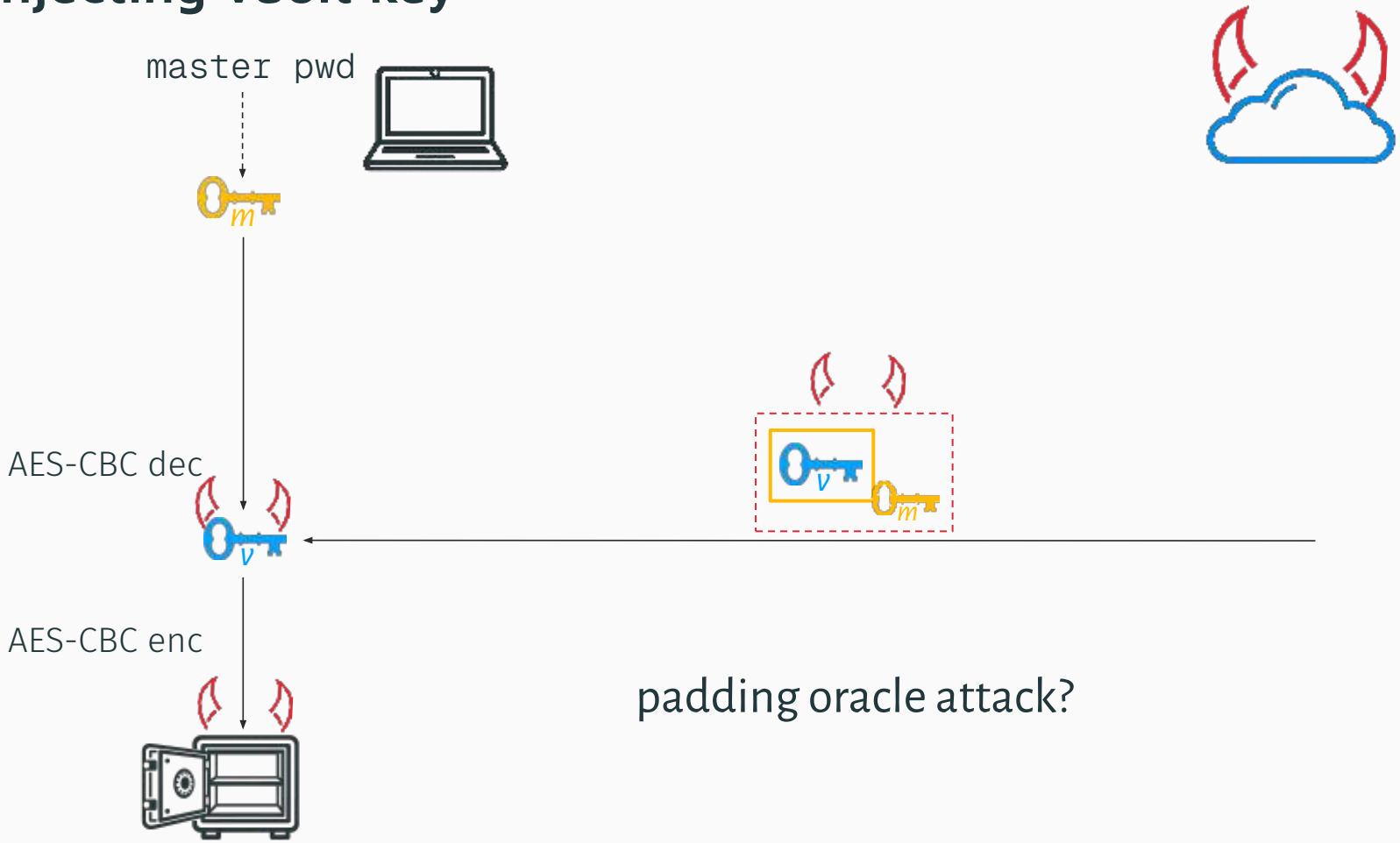
Injecting vault key



Injecting vault key

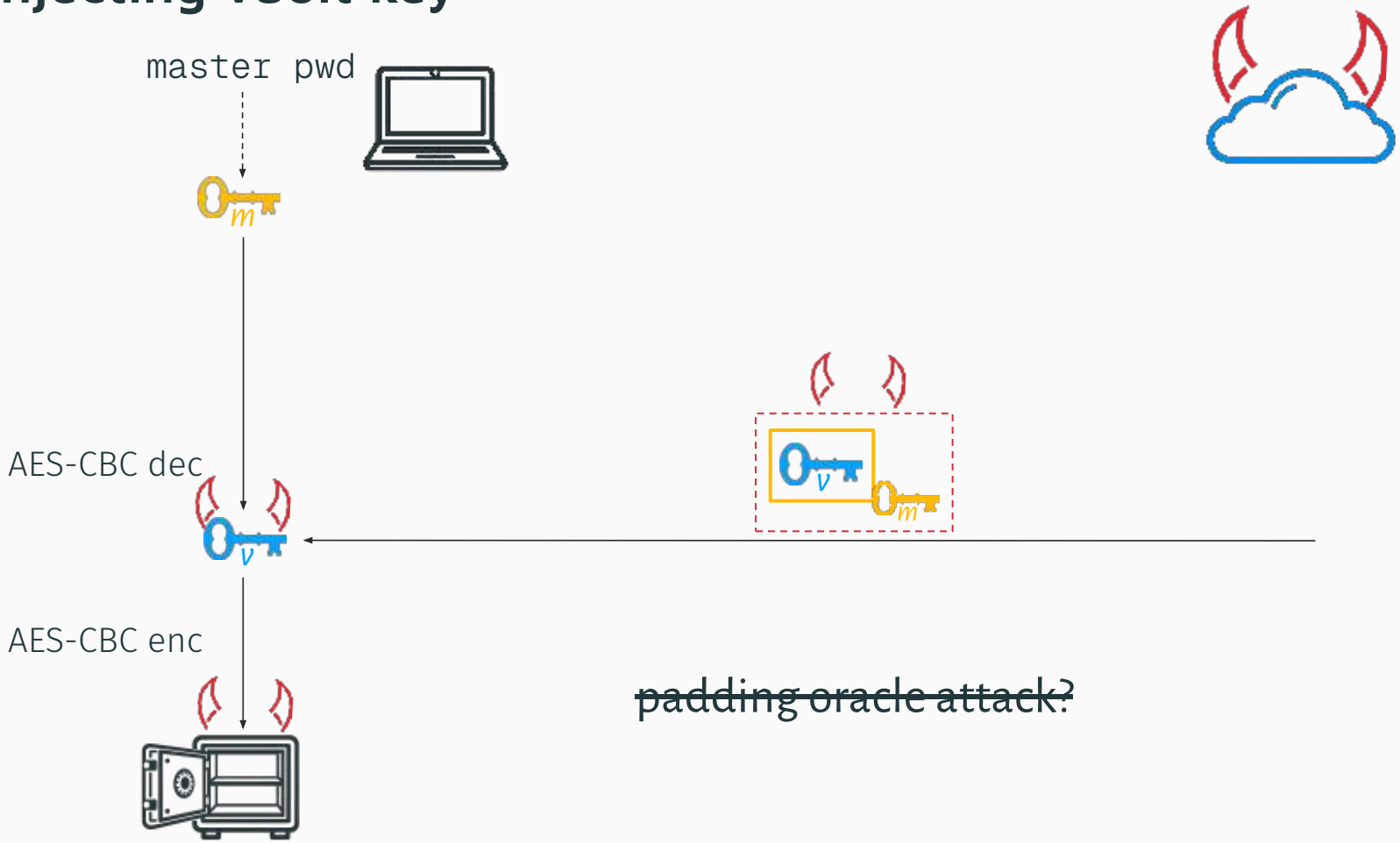


Injecting vault key



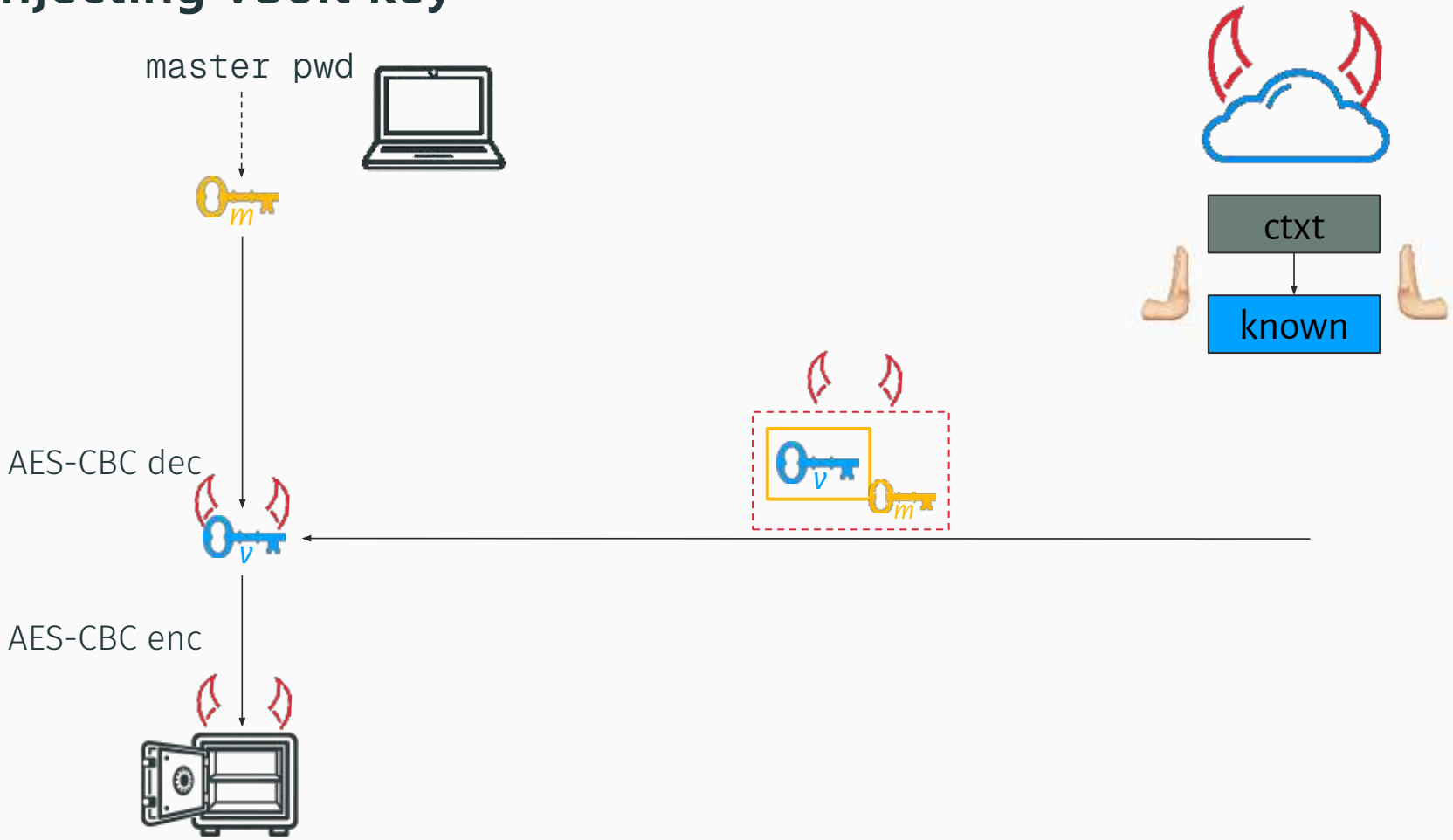
padding oracle attack?

Injecting vault key

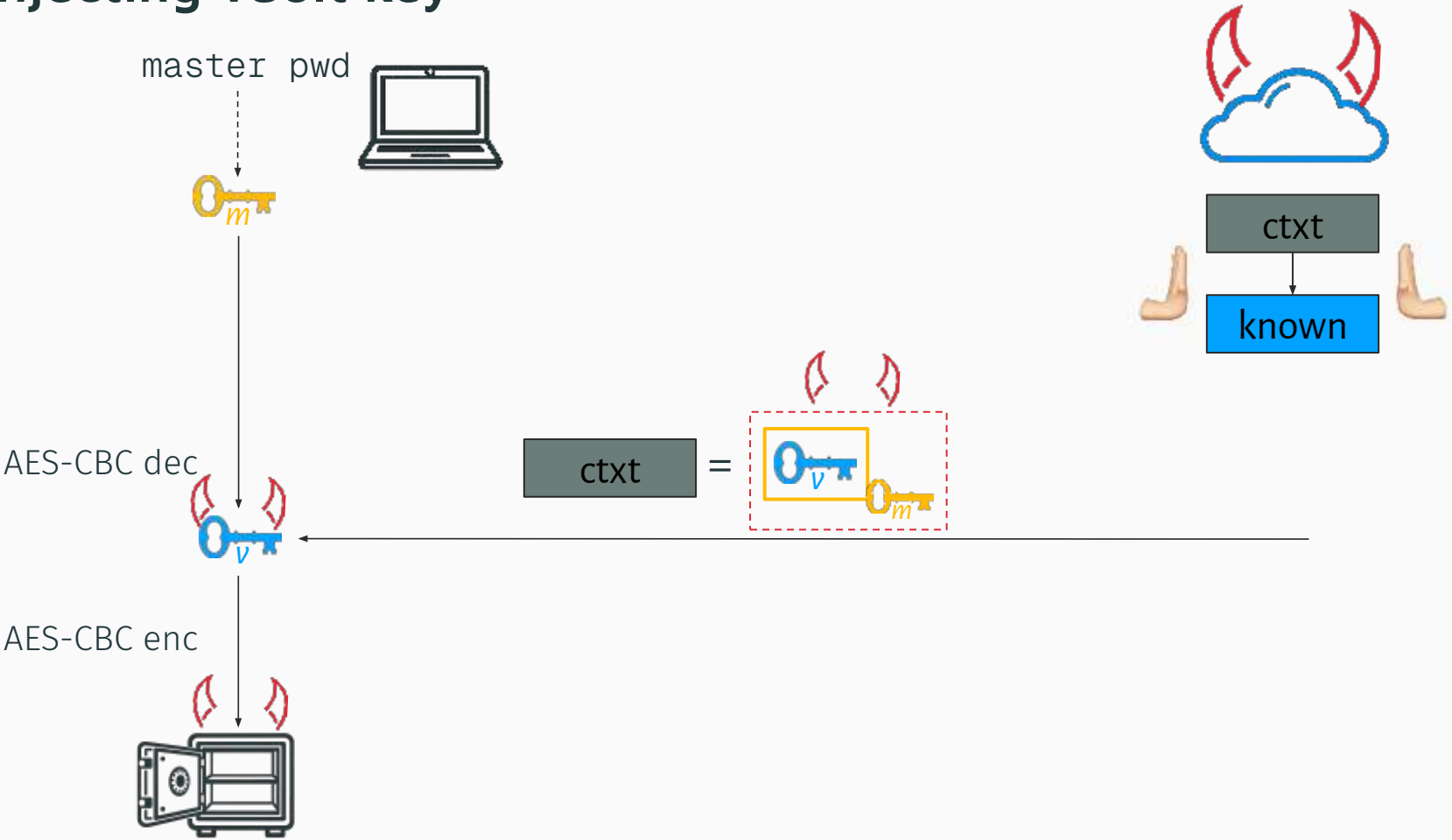


~~padding oracle attack?~~

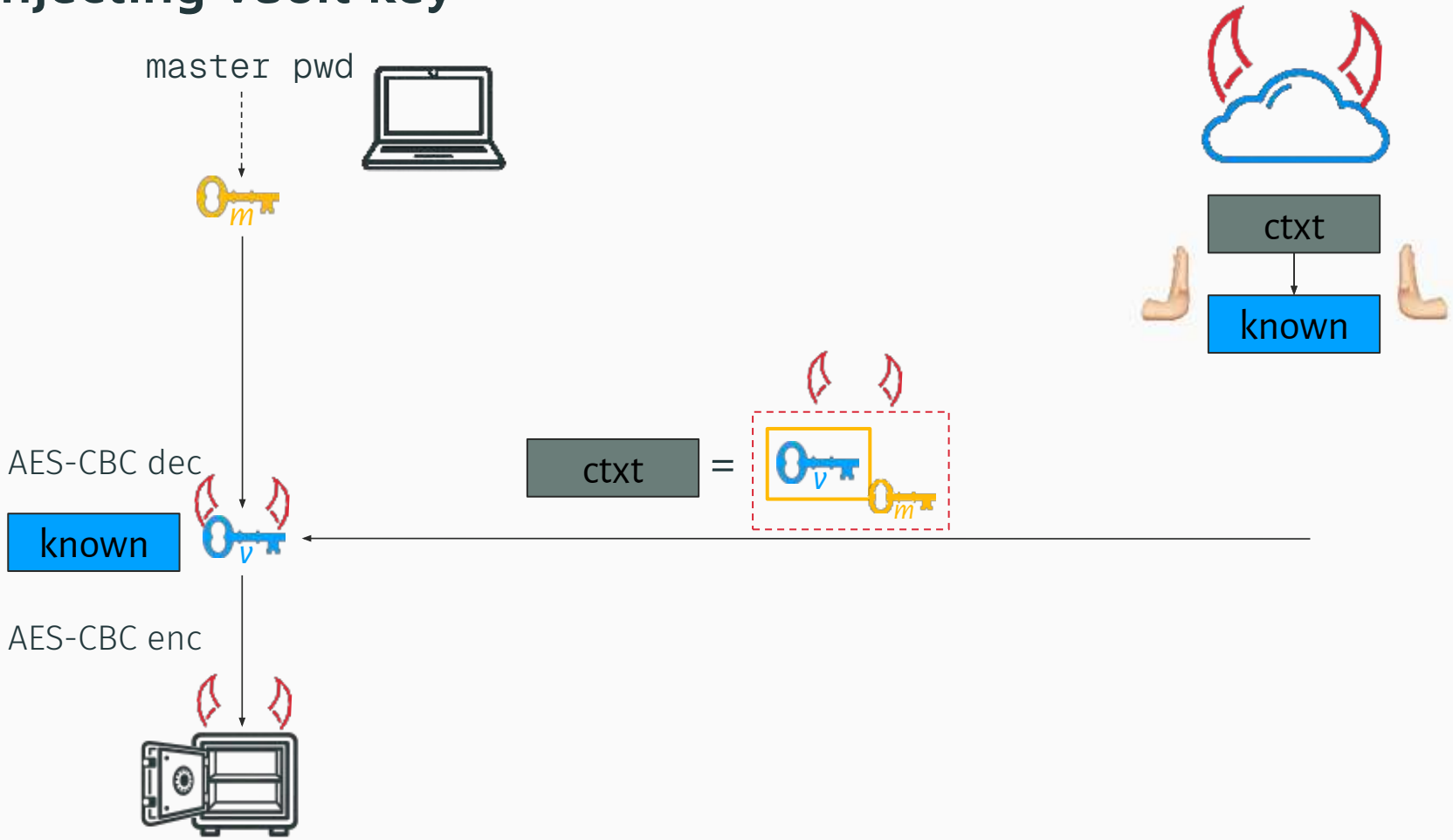
Injecting vault key



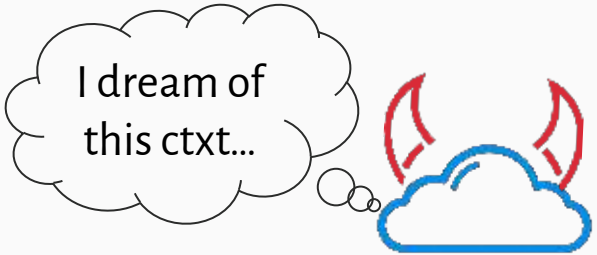
Injecting vault key

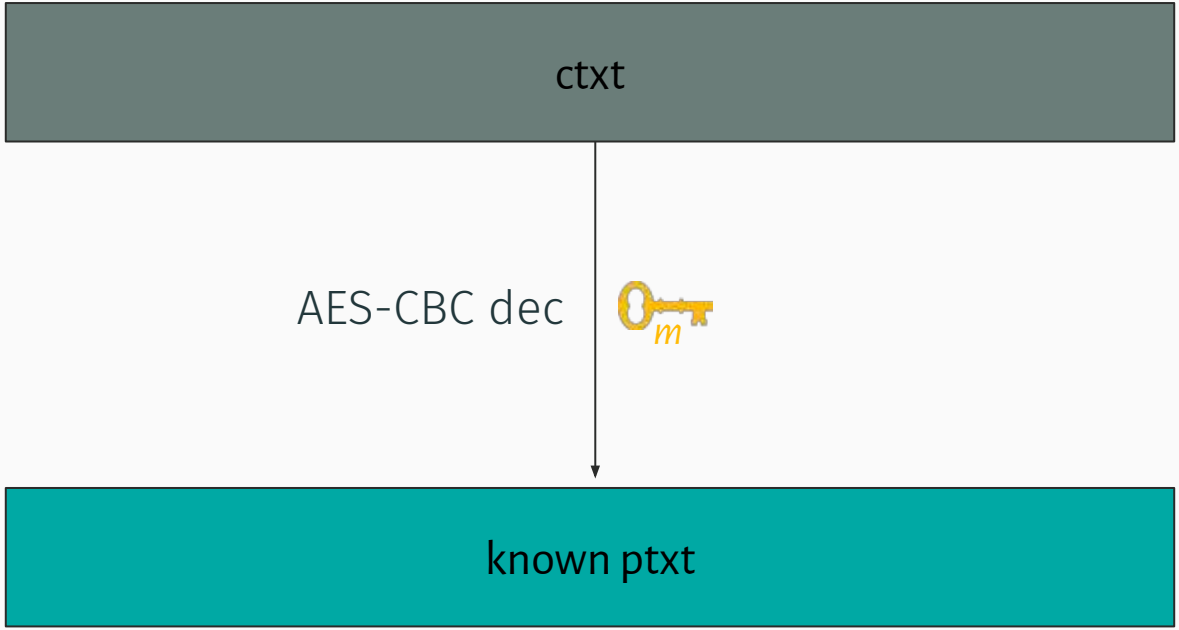


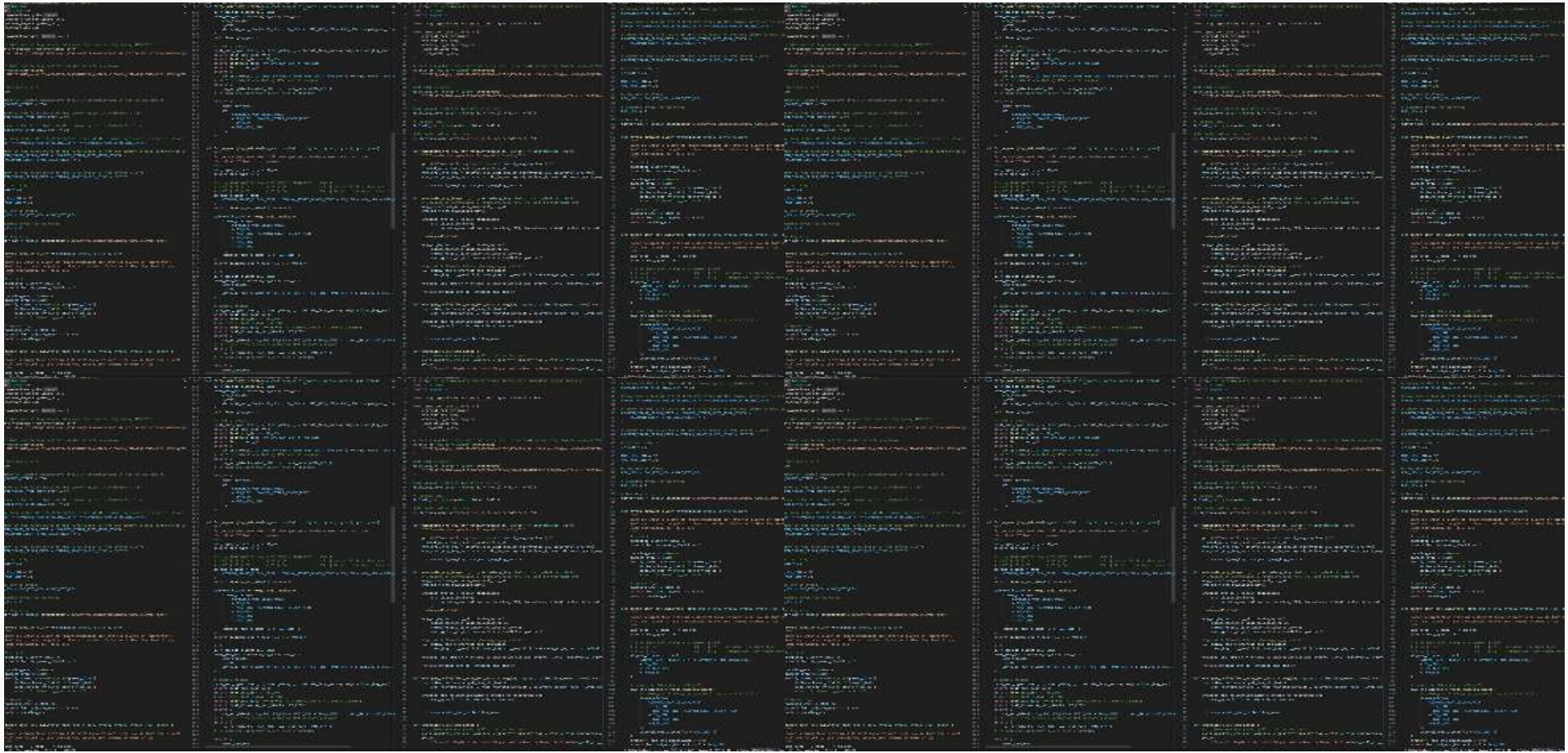
Injecting vault key



What the server wants

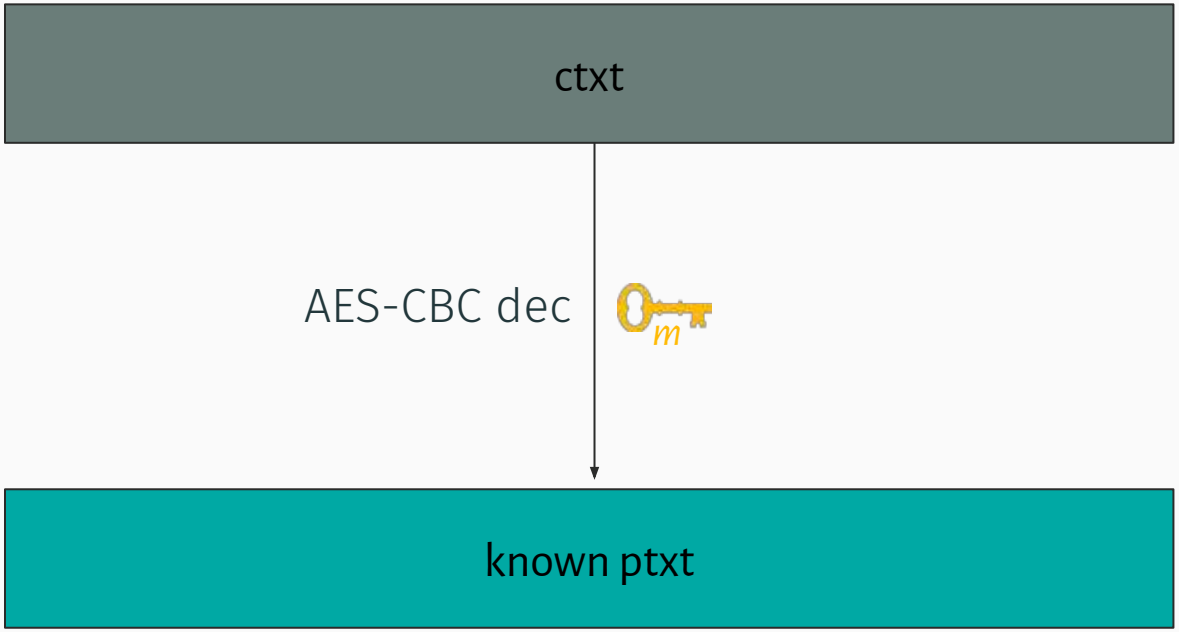




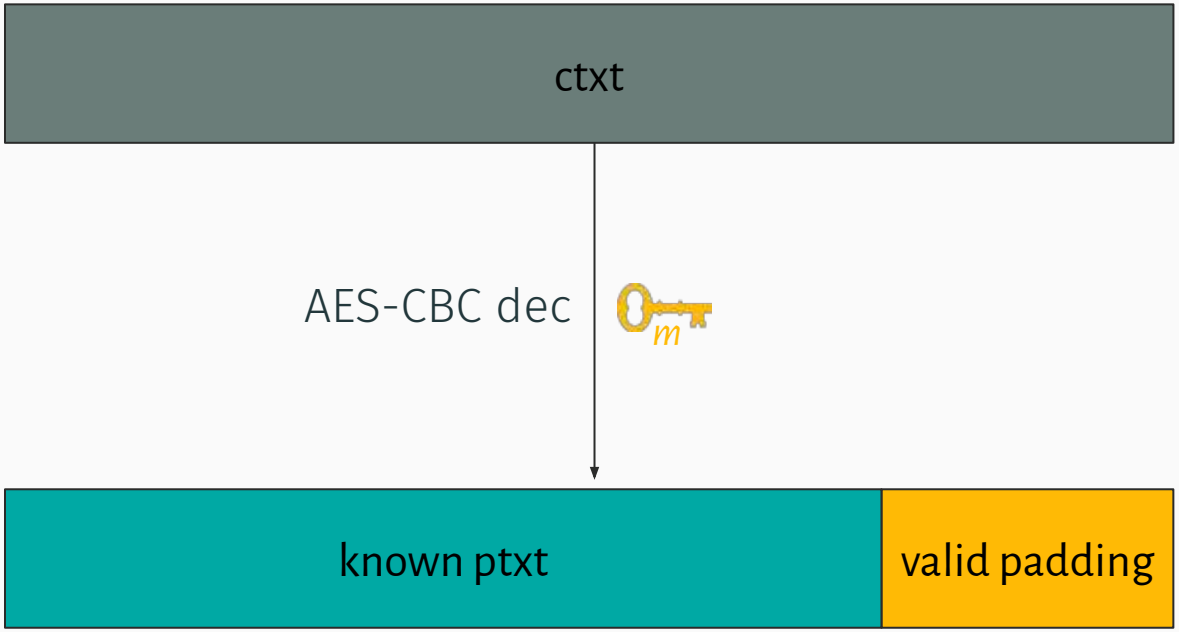


here!

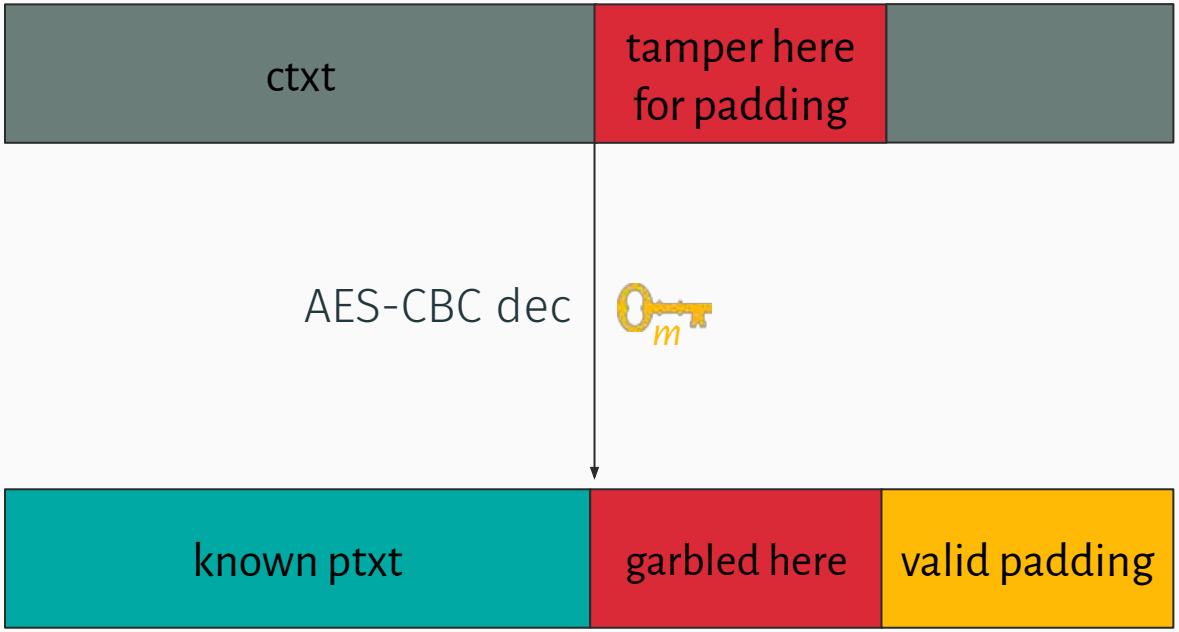
✅ Known ctxt-ptxt pair



But, no free lunch…

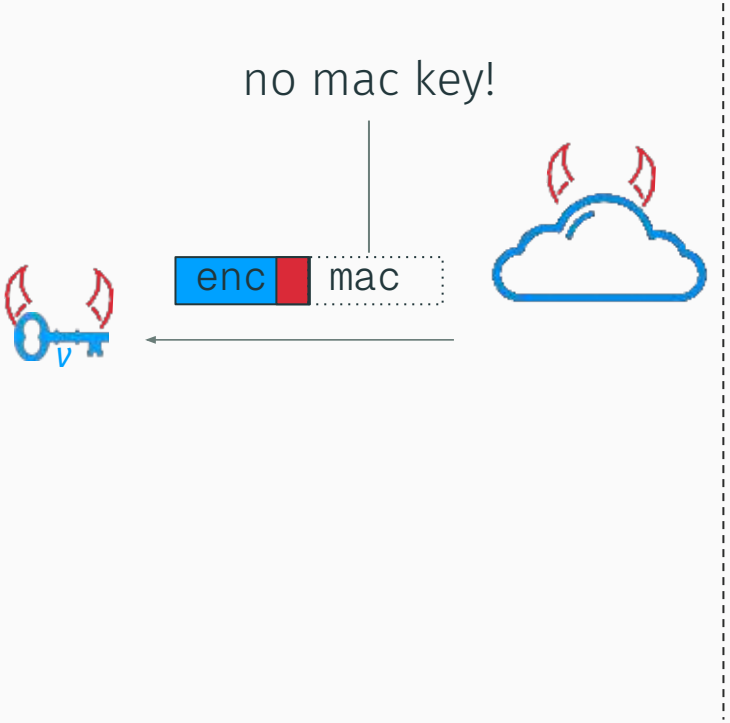


But, no free lunch...

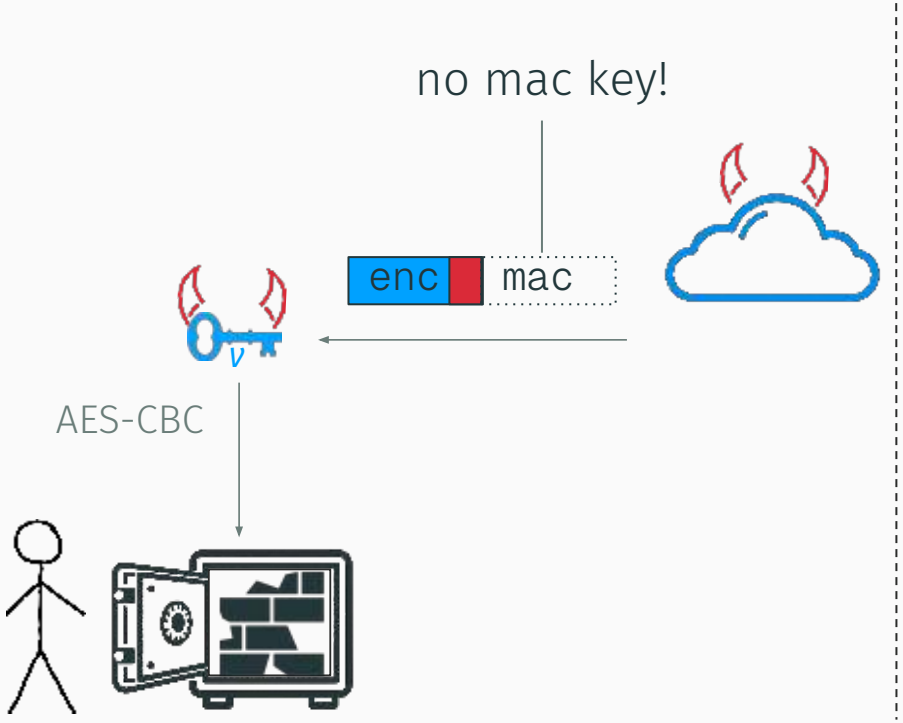


The Heisenberg Attack

The Heisenberg Attack

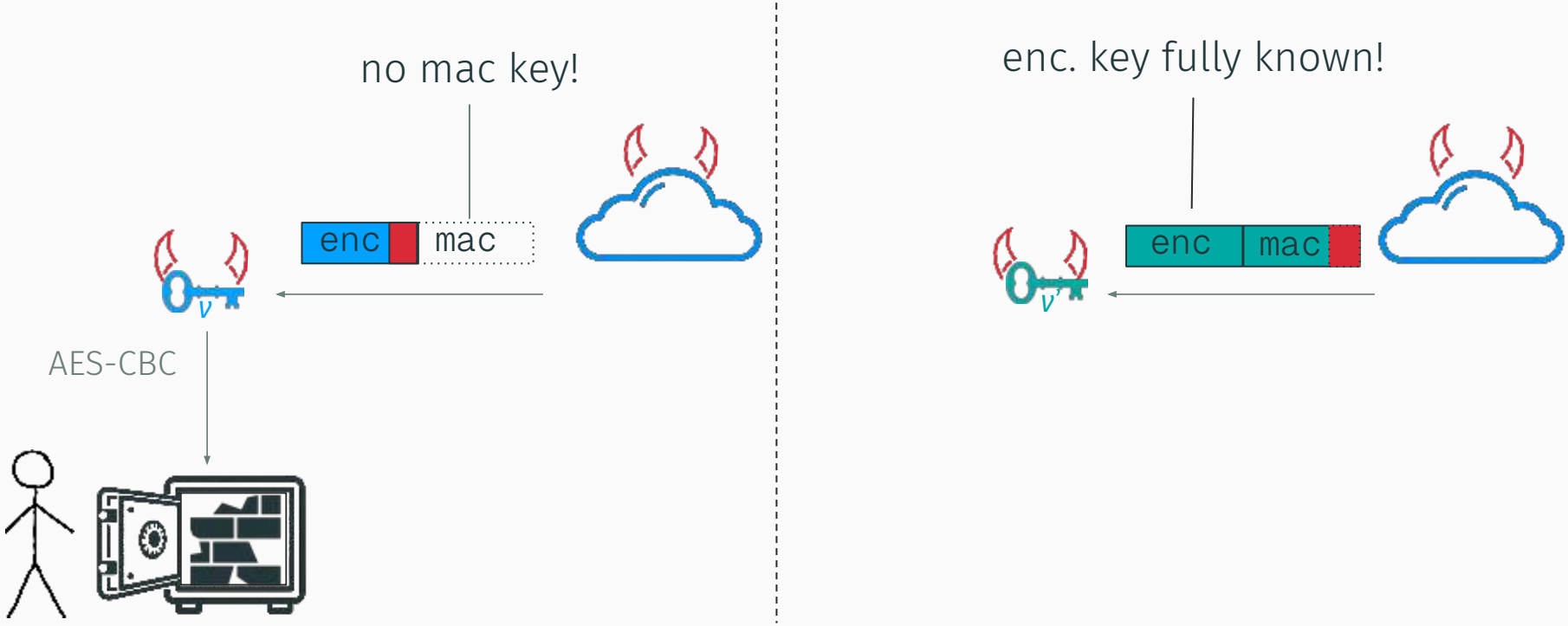


The Heisenberg Attack



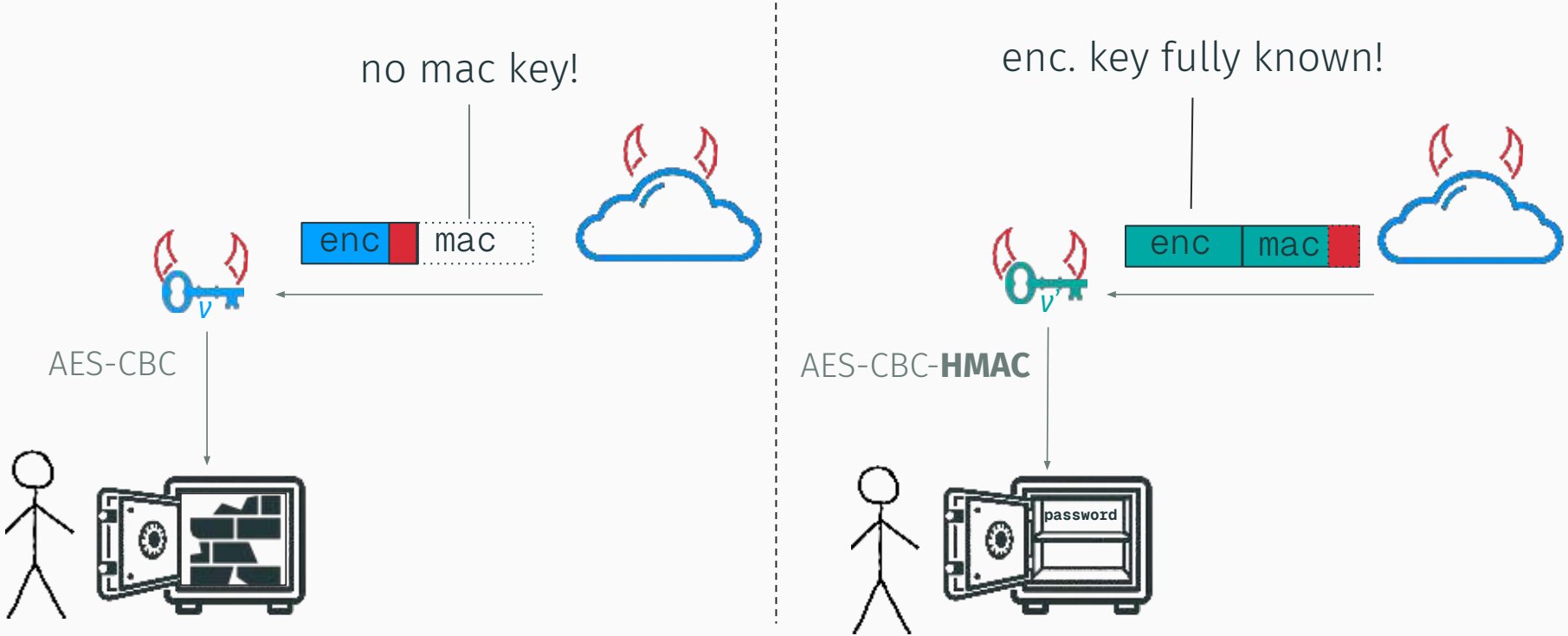
No integrity

The Heisenberg Attack



No integrity

The Heisenberg Attack



No integrity **OR** **No confidentiality**

Recap

Risky Features

Key Recovery

Partial Vault Sync

Sharing

Backwards Compatibility

Risky Features

Key Recovery

Partial Vault Sync

Sharing

Backwards Compatibility

Today:
~⅓ of the Attacks

(for more, check our paper!)

Risky Features

Key
Recovery

Sharing

Risky Features

Key Recovery

Sharing

Risky Features

Key Recovery

Sharing

Secret Key Recovery in a Global-Scale End-to-End Encryption System

Graeme Connell*
Signal Messenger

Vivian Fang*
UC Berkeley

Rolfe Schmidt*
Signal Messenger

Emma Dauterman
UC Berkeley

Raluca Ada Popa
UC Berkeley

Parakeet: Practical Key Transparency for End-to-End Encrypted Messaging

Harjasleen Malvai*, Lefteris Kokoris-Kogias[=§], Alberto Sonnino[‡¶], Esha Ghosh[‖],
Ercan Oztürk**, Kevin Lewi**, and Sean Lawlor[++]
[*]UIUC, [=]IC3. [‡]Mysten Labs, [§]IST Austria, [¶]University College London (UCL), [‖]Microsoft Research. [++]Meta

Risky Features

Partial Vault Sync

Risky Features

Partial Vault Sync

KEY SEPARATION

Risky Features

Backwards
Compatibility

Risky Features

Backwards Compatibility

Disclosure & Mitigations

Disclosure & Mitigations

Disclosure & Mitigations

Zero-Knowledge Encryption?

Zero Knowledge About Encryption?

https://zkae.io

ia.cr/2026/058

scarlata.matteo@inf.ethz.ch

giovanni.torrisi@usi.ch

Zero Knowledge About Encryption?